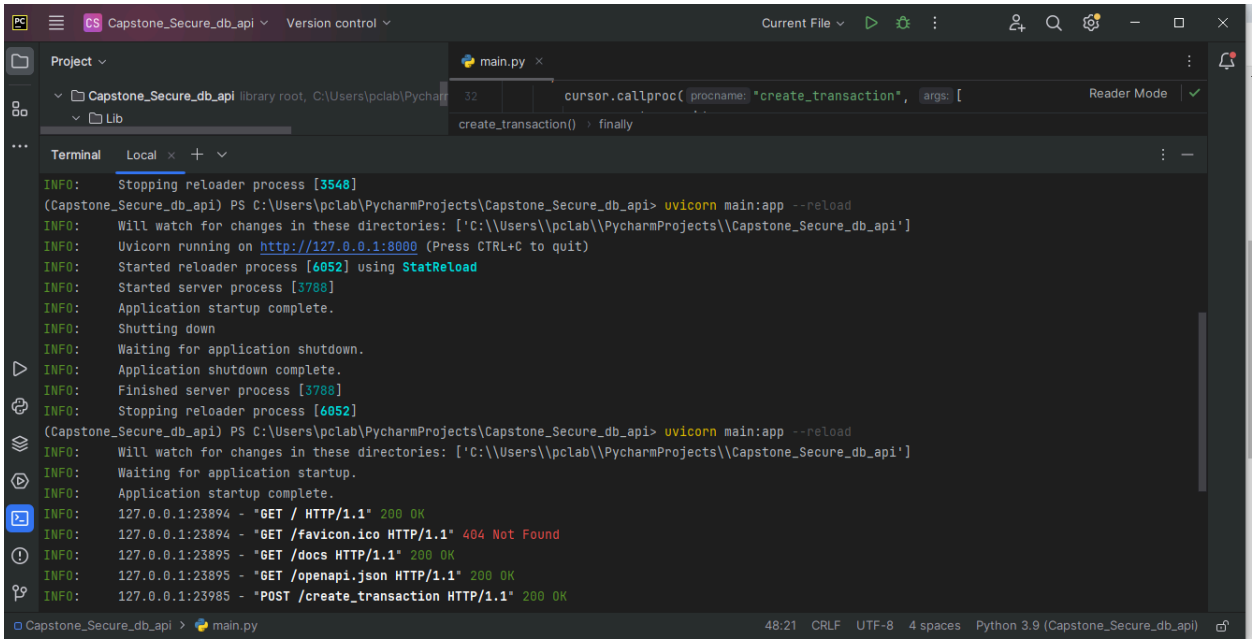
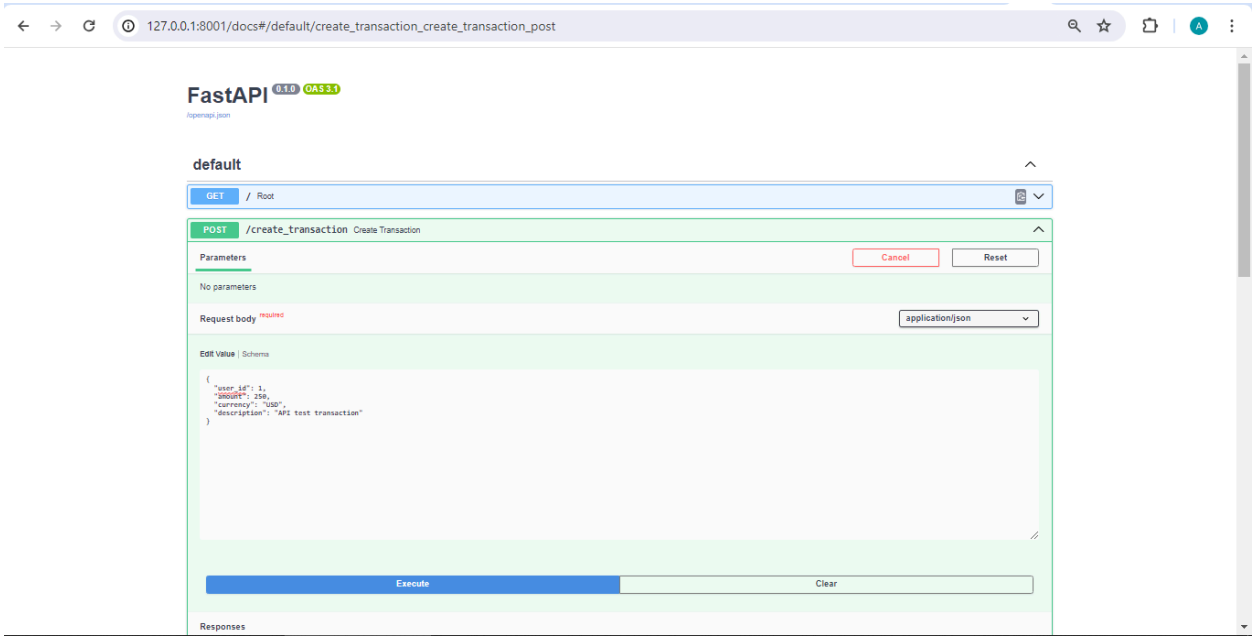
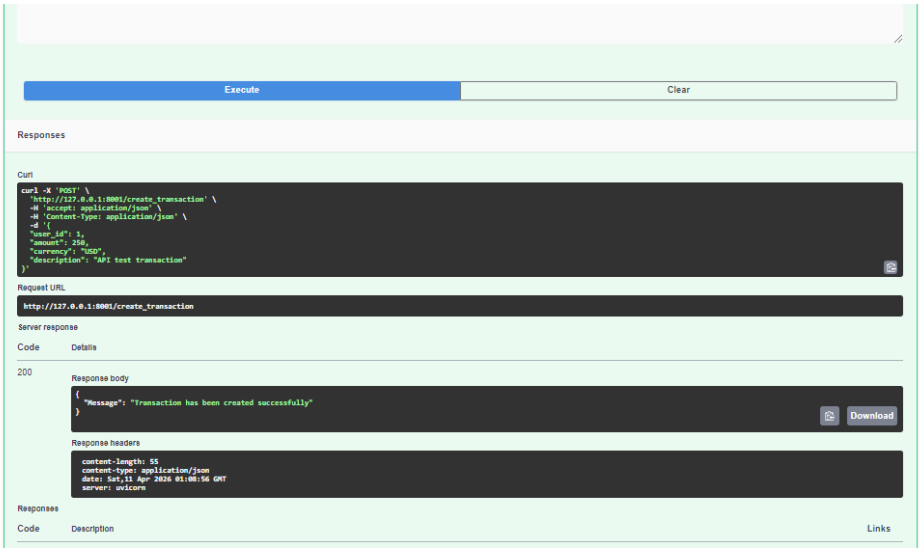
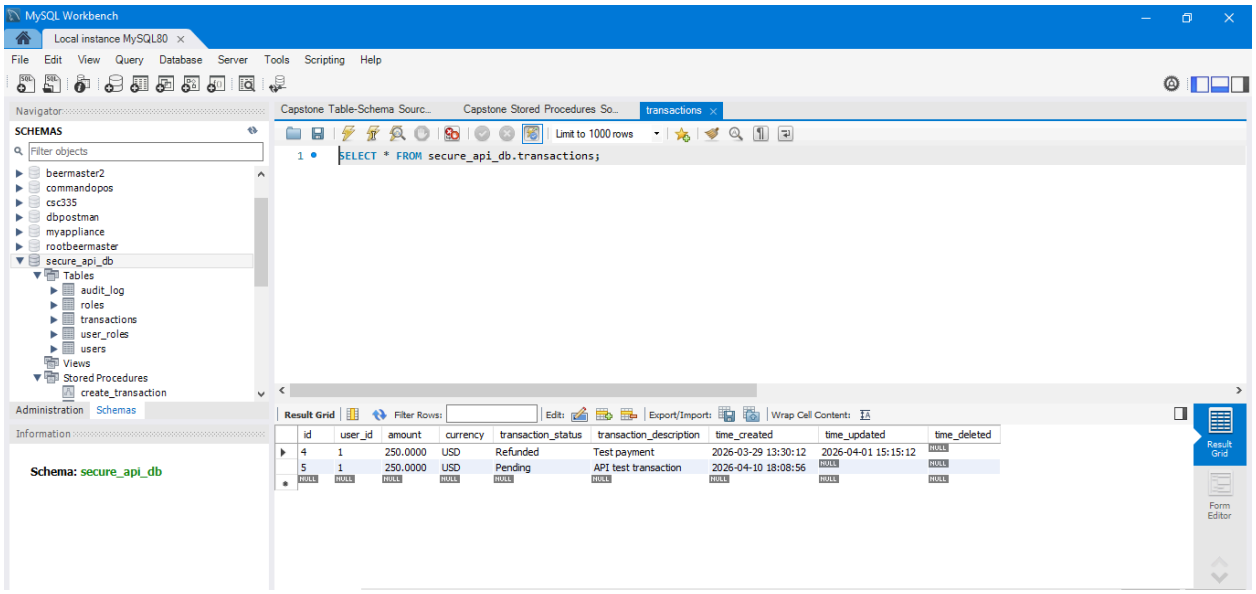
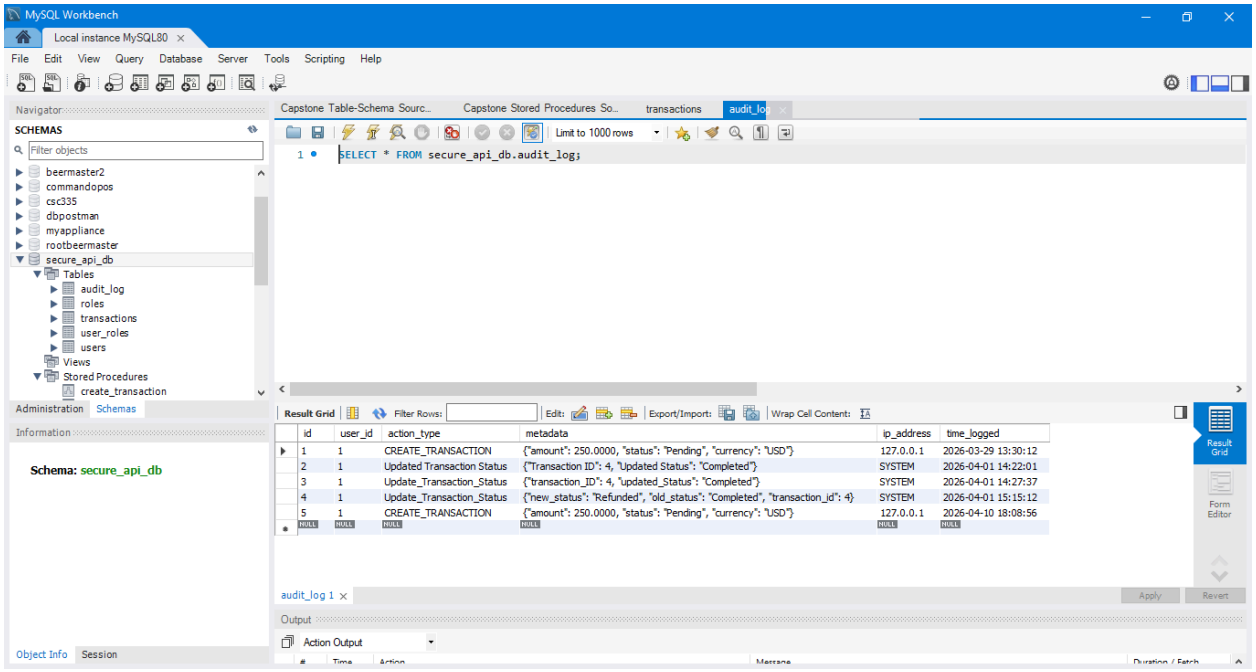
The following images show the successful connection of FastAPI, Python, and MySQL proof:



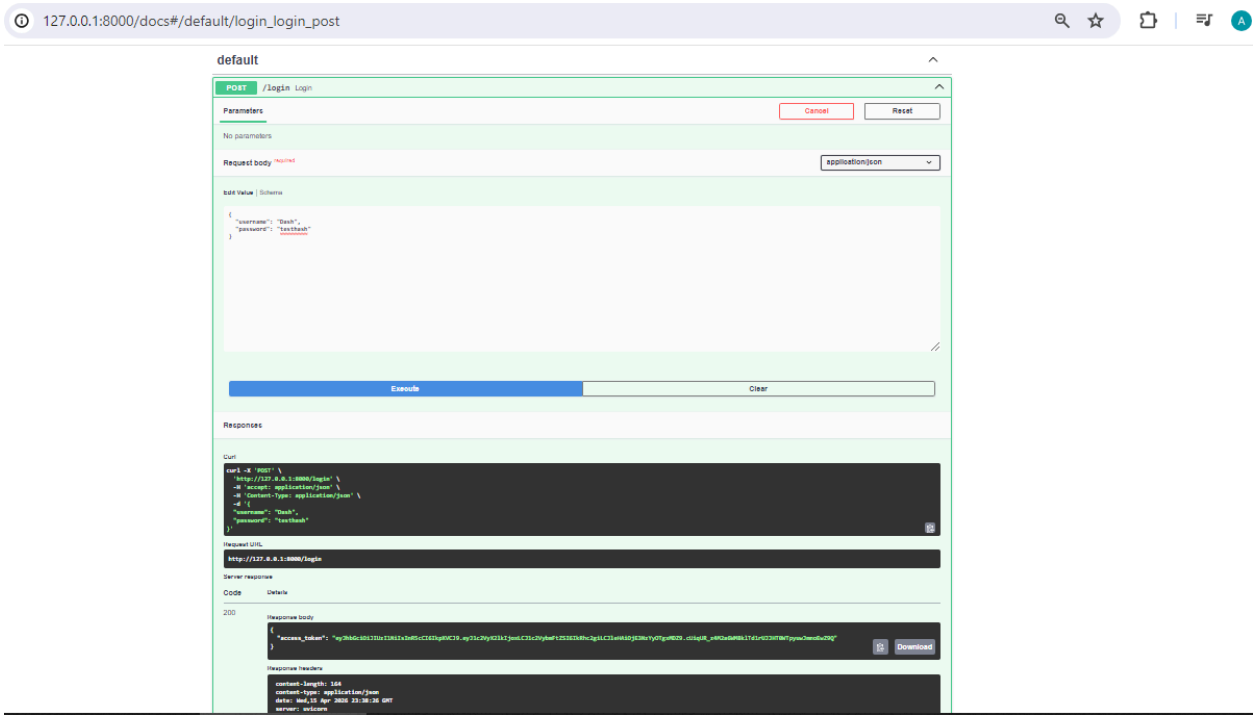


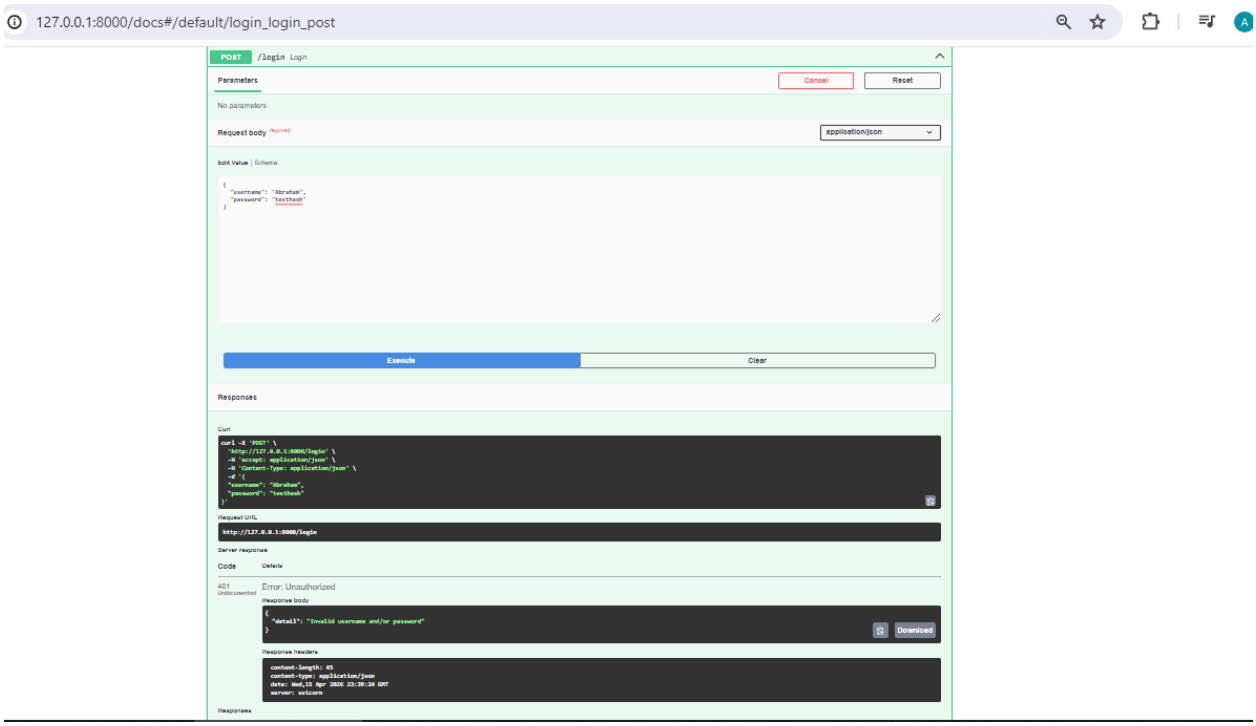

Execute
Clear
Responses
Curl
curl -X 'POST' \
'http://127.0.0.1:8001/create_transaction' \
-H 'accept: application/json' \
-H 'Content-Type: application/json' \
-d '{
"user_id": 1,
"amount": 250,
"currency": "USD",
"description": "API test transaction"
}'
Request URL
http://127.0.0.1:8001/create_transaction
Server response
Code
Details
200
Response body
{
"Message": "Transaction has been created successfully"
}
Download
Response headers
content-length: 55
content-type: application/json
date: Sat,11 Apr 2026 01:08:56 GMT
server: uvicorn
Responses
Code
Description
Links


MySQL Workbench
Local instance MySQL80
File Edit View Query Database Server Tools Scripting Help
Navigator
SCHEMAS
Filter objects
beermaster2
commandopos
csc335
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
create_transaction
Administration Schemas
Information
Schema: secure_api_db
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
transactions
Limit to 1000 rows
1 SELECT * FROM secure_api_db.transactions;
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Cell Content:
id user_id amount currency transaction_status transaction_description time_created time_updated time_deleted
4 1 250.0000 USD Refunded Test payment 2026-03-29 13:30:12 2026-04-01 15:15:12 NULL
5 1 250.0000 USD Pending API test transaction 2026-04-10 18:08:56 NULL NULL
Result Grid
Form Editor

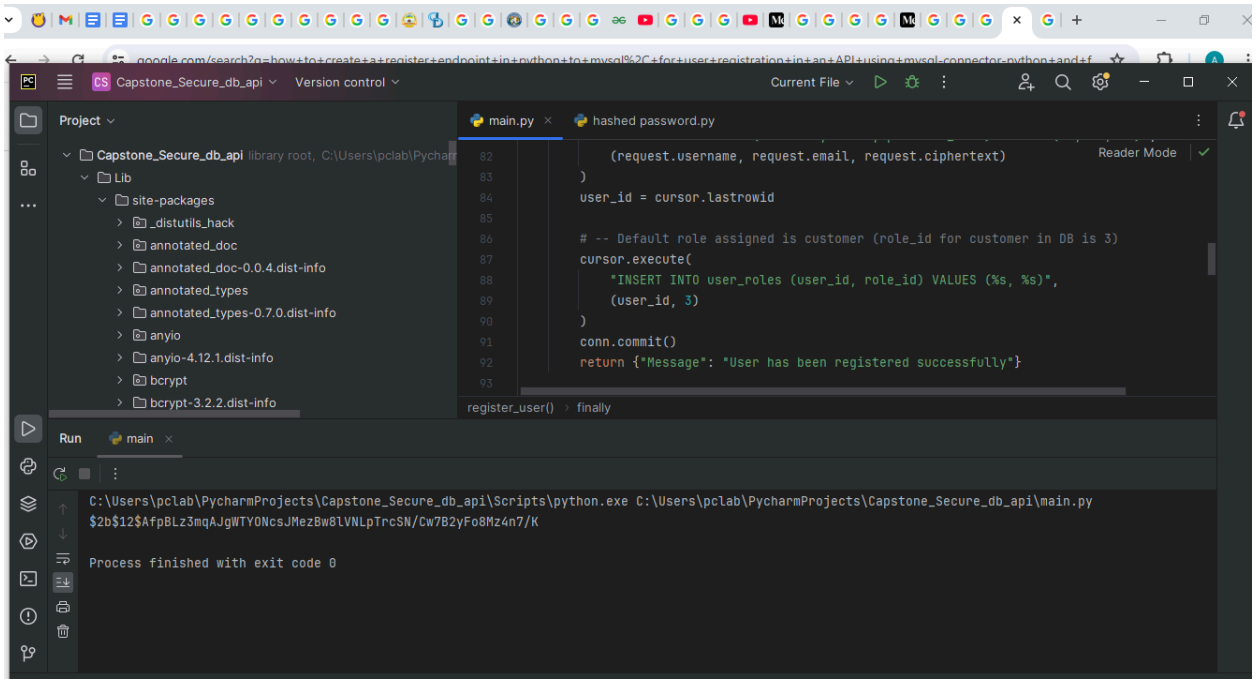

MySQL Workbench
Local instance MySQL80
File Edit View Query Database Server Tools Scripting Help
Navigator
SCHEMAS
Filter objects
beermaster2
commandopos
csc335
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
create_transaction
Administration Schemas
Information
Schema: secure_api_db
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
transactions
audit_log
Limit to 1000 rows
1 SELECT * FROM secure_api_db.audit_log;
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Cell Content:
id user_id action_type metadata ip_address time_logged
1 1 CREATE_TRANSACTION {"amount": 250.0000, "status": "Pending", "currency": "USD"} 127.0.0.1 2026-03-29 13:30:12
2 1 Updated Transaction Status {"Transaction ID": 4, "Updated Status": "Completed"} SYSTEM 2026-04-01 14:22:01
3 1 Update_Transaction_Status {"transaction_ID": 4, "updated_Status": "Completed"} SYSTEM 2026-04-01 14:27:37
4 1 Update_Transaction_Status {"new_status": "Refunded", "old_status": "Completed", "transaction_id": 4} SYSTEM 2026-04-01 15:15:12
5 1 CREATE_TRANSACTION {"amount": 250.0000, "status": "Pending", "currency": "USD"} 127.0.0.1 2026-04-10 18:08:56
audit_log 1
Apply
Revert
Output
Action Output
Object Info Session

The following images show a successful login where it responds with a valid access token, and a failed attempt with an error message as the response:





The following is an image of the hashed user password/ciphertext:



The following images demonstrate failed JWT tamper attempts:

Authorize

```
curl -X 'POST' \
  'http://127.0.0.1:8000/login' \
  -H 'accept: application/json' \
  -H 'content-type: application/json' \
  -d '{
  "username": "Dash",
  "password": "testhash"
}'
```

Request URL

```
http://127.0.0.1:8000/login
```

Server response

Code	Details
200	Response body

```
{
  "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLCJleHAiOjE3NzY5MDE0ODl9.i7ULEYSYoyv37CvUmNx69M29WXV4t8SKl4TZGwv4r7k"
}
```

Download

Response headers

```
content-length: 164
content-type: application/json
date: Wed,22 Apr 2026 23:14:48 GMT
server: uvicorn
```

Responses

Code	Description	Links
200	Successful Response	*No links*

Media type: application/json

Controls Accept header.

Curl

```
curl -X 'POST' \
  'http://127.0.0.1:8000/create_transaction' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLCJleHAiOjE3NzY5MDE0ODl9.i7ULEYSYoyv37CvUmNx69M29WXV4t8SKl4TZGwv4r7f' \
  -H 'content-Type: application/json' \
  -d '{
  "amount": 25.00,
  "currency": "USD",
  "description": "Failed attempt"
}'
```

Request URL

```
http://127.0.0.1:8000/create_transaction
```

Server response

Code	Details
401 *Undocumented*	Error: Unauthorized

Response body

```
{
  "detail": "Invalid or expired token"
}
```

Download

Response headers

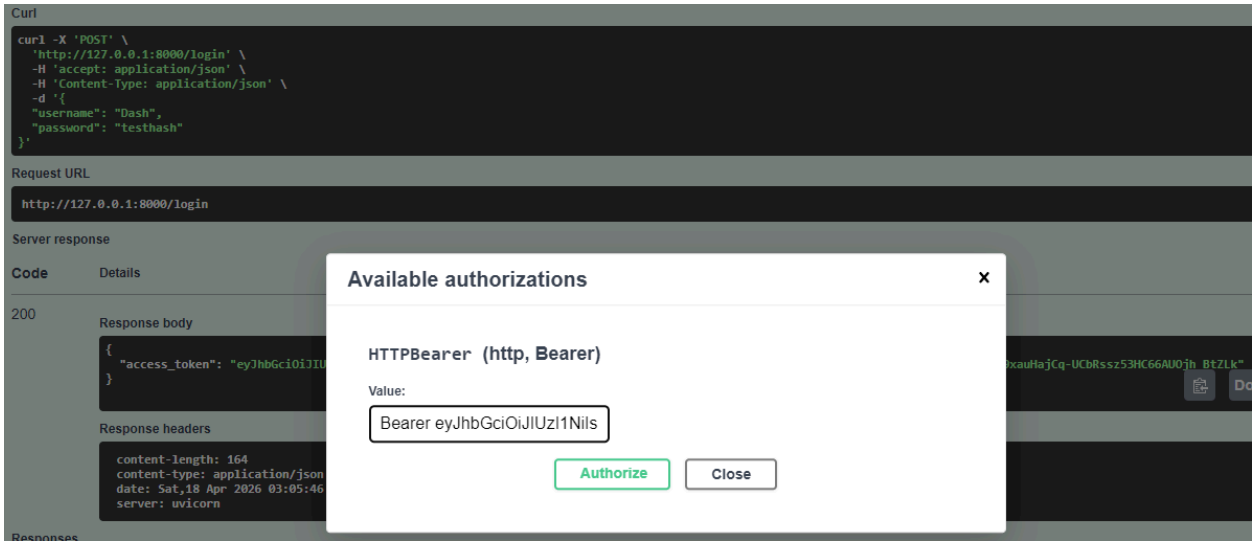
```
content-length: 37
content-type: application/json
date: Wed,22 Apr 2026 23:17:38 GMT
server: uvicorn
```

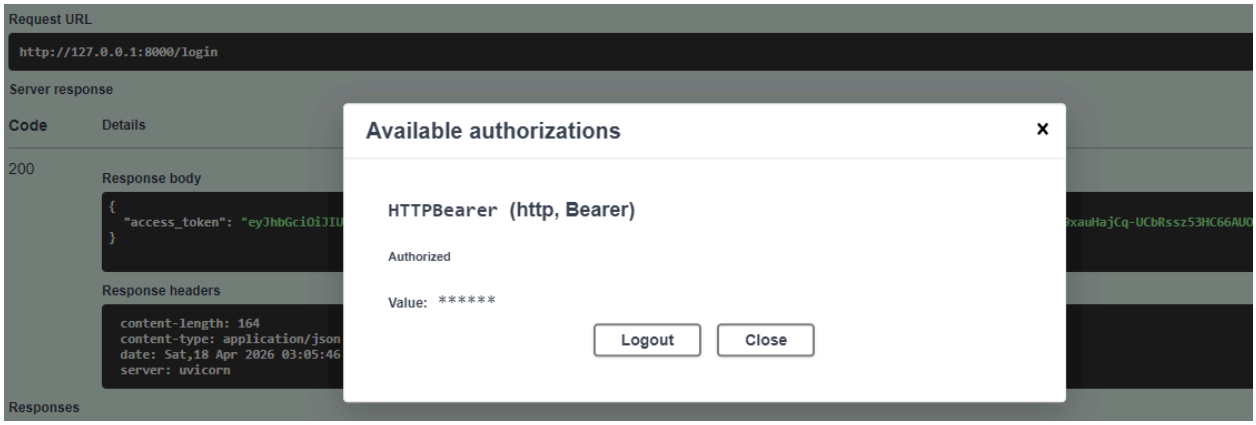
Responses

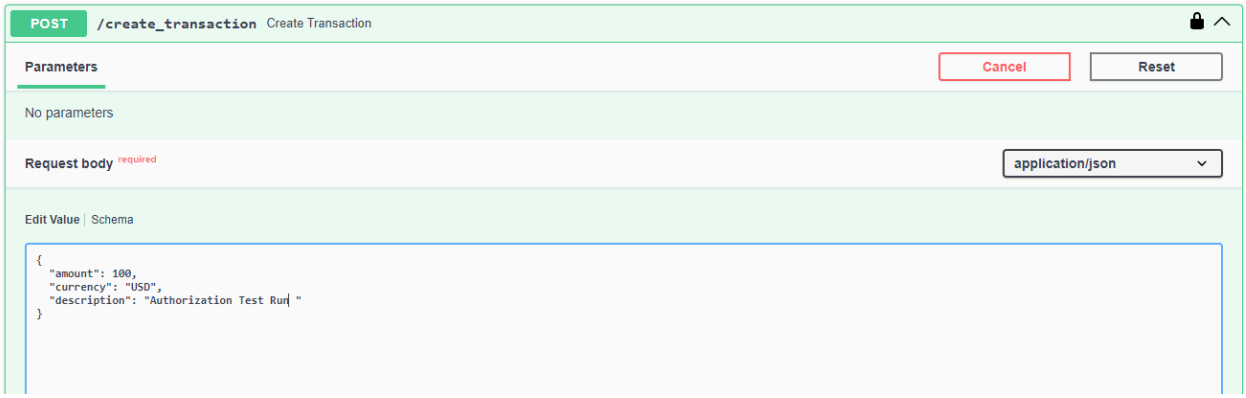
Code	Description	Links

The following images show the process of logging in and authorizing with the access token to create and update transactions, and proof in MySQL:









Curl

```
curl -X 'POST' \
  'http://127.0.0.1:8000/create_transaction' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLCJleHAiOjE3NzY0ODk0MDV9.1mBC12KXkY0wJUq0PbrSZm7kuO_KjdHHpHQb6U3X94A' \
  -H 'Content-Type: application/json' \
  -d '{
  "amount": 100,
  "currency": "USD",
  "description": "Auth test run"
}'
```

Request URL

```
http://127.0.0.1:8000/create_transaction
```

Server response

Code	Details
200	Response body

```
{
  "Message": "Transaction has been created successfully"
}
```

Download

Response headers

```
content-length: 55
content-type: application/json
date: Sat,18 Apr 2026 04:47:50 GMT
server: uvicorn
```

Responses

Curl

```
curl -X 'POST' \
  'http://127.0.0.1:8000/update_transaction' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLCJleHAiOjE3NzY0ODk0MDV9.1mBC12KXkY0wJUq0PbrSZm7kuO_KjdHHpHQb6U3X94A' \
  -H 'Content-Type: application/json' \
  -d '{
  "transaction_id": "6",
  "new_status": "Completed"
}'
```

Request URL

```
http://127.0.0.1:8000/update_transaction
```

Server response

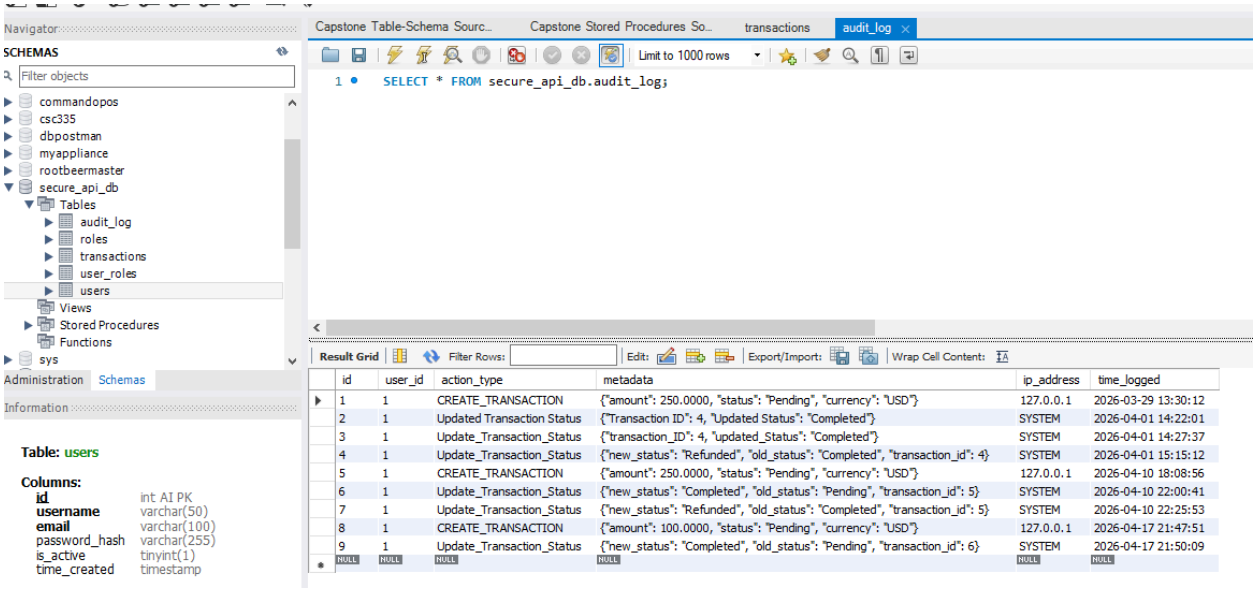
Code	Details
200	Response body

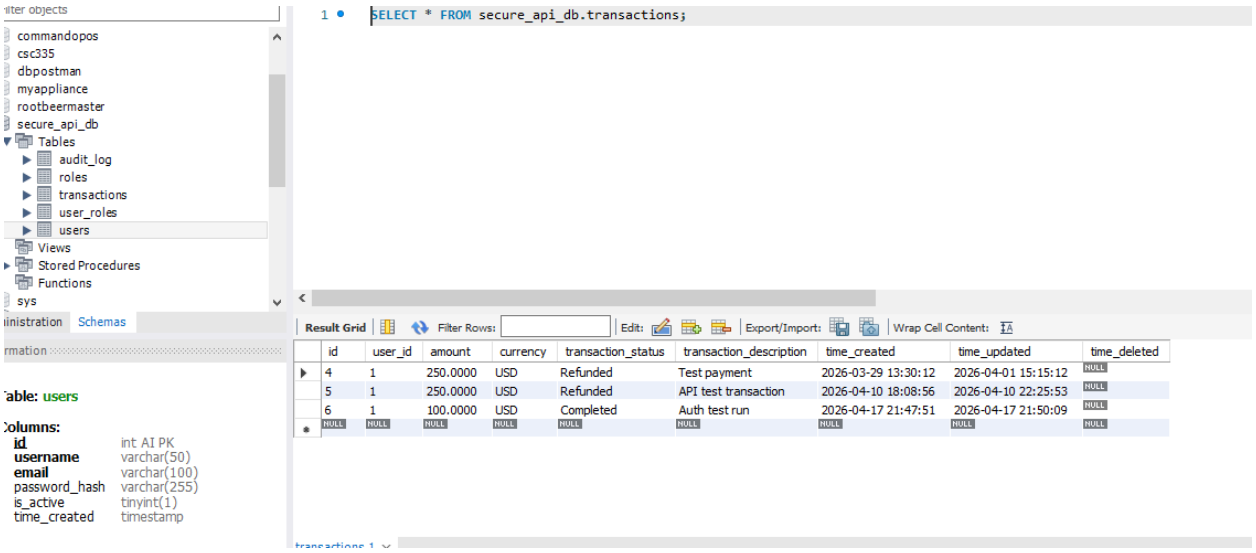
```
{
  "Message": "Transaction has been updated successfully"
}
```

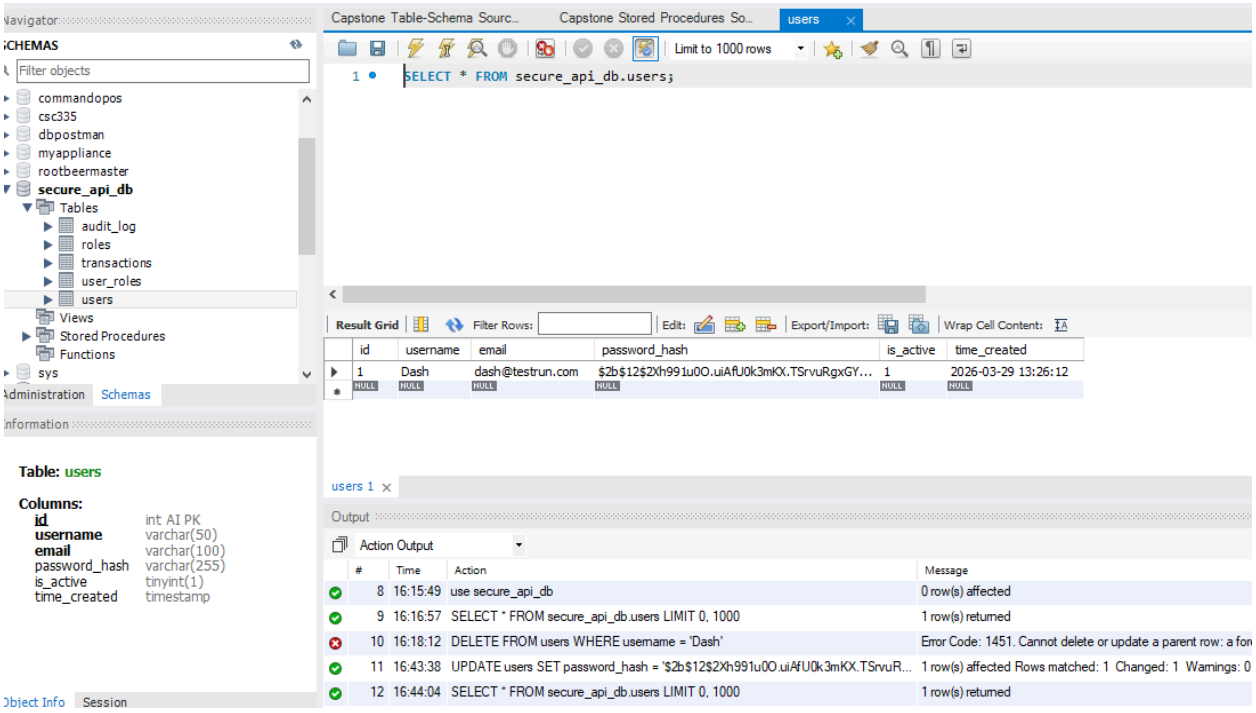
Response headers

```
content-length: 55
content-type: application/json
date: Sat,18 Apr 2026 04:50:08 GMT
server: uvicorn
```

Responses

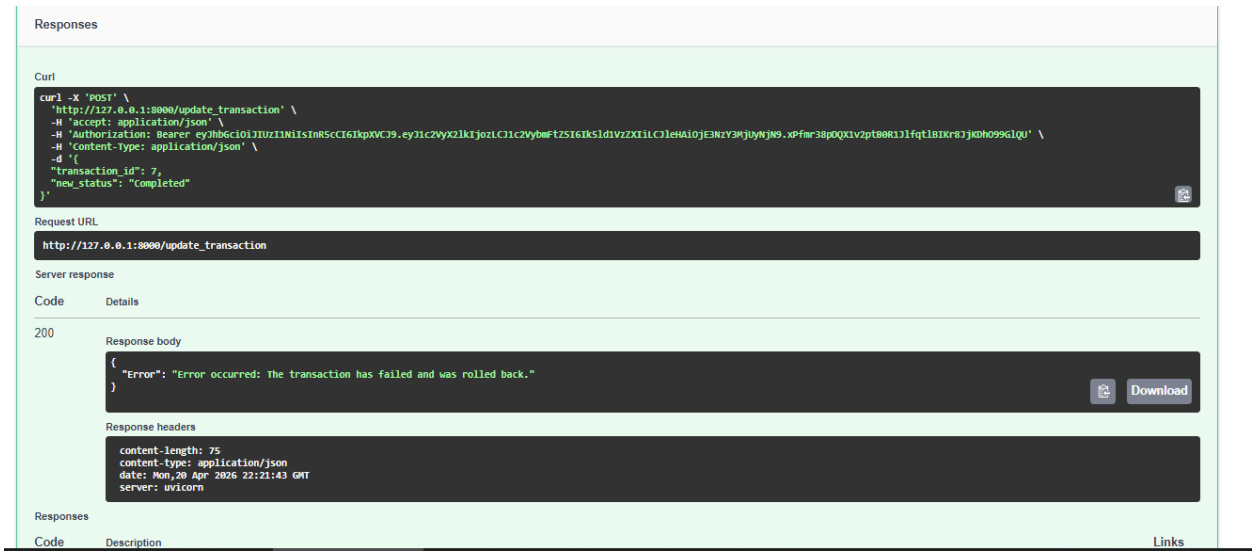

Navigator
SCHEMAS
Filter objects
commandopos
csc335
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
Functions
sys
Administration
Schemas
Information
Table: users
Columns:
id int AI PK
username varchar(50)
email varchar(100)
password_hash varchar(255)
is_active tinyint(1)
time_created timestamp
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
transactions
audit_log
Limit to 1000 rows
1 SELECT * FROM secure_api_db.audit_log;
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Cell Content:
id user_id action_type metadata ip_address time_logged
1 1 CREATE_TRANSACTION {"amount": 250.0000, "status": "Pending", "currency": "USD"} 127.0.0.1 2026-03-29 13:30:12
2 1 Updated Transaction Status {"Transaction ID": 4, "Updated Status": "Completed"} SYSTEM 2026-04-01 14:22:01
3 1 Update_Transaction_Status {"transaction_ID": 4, "updated_Status": "Completed"} SYSTEM 2026-04-01 14:27:37
4 1 Update_Transaction_Status {"new_status": "Refunded", "old_status": "Completed", "transaction_id": 4} SYSTEM 2026-04-01 15:15:12
5 1 CREATE_TRANSACTION {"amount": 250.0000, "status": "Pending", "currency": "USD"} 127.0.0.1 2026-04-10 18:08:56
6 1 Update_Transaction_Status {"new_status": "Completed", "old_status": "Pending", "transaction_id": 5} SYSTEM 2026-04-10 22:00:41
7 1 Update_Transaction_Status {"new_status": "Refunded", "old_status": "Completed", "transaction_id": 5} SYSTEM 2026-04-10 22:25:53
8 1 CREATE_TRANSACTION {"amount": 100.0000, "status": "Pending", "currency": "USD"} 127.0.0.1 2026-04-17 21:47:51
9 1 Update_Transaction_Status {"new_status": "Completed", "old_status": "Pending", "transaction_id": 6} SYSTEM 2026-04-17 21:50:09
NULL NULL NULL NULL NULL NULL

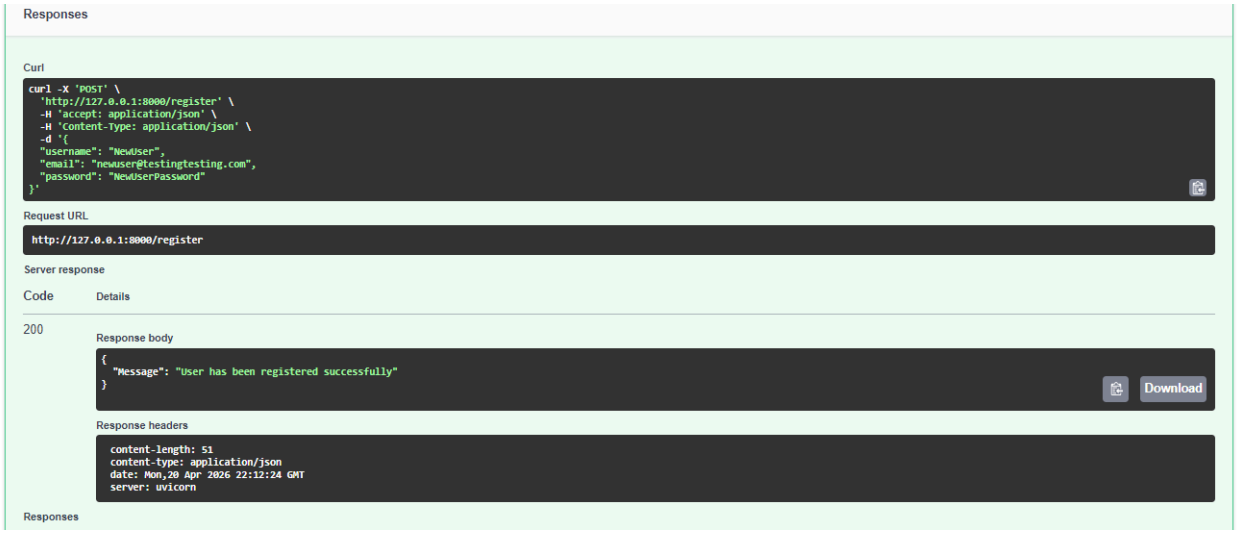

Filter objects
commandopos
csc335
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
Functions
sys
Schemas
Table: users
Columns:
id int AI PK
username varchar(50)
email varchar(100)
password_hash varchar(255)
is_active tinyint(1)
time_created timestamp
1 SELECT * FROM secure_api_db.transactions;
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Cell Content:
id user_id amount currency transaction_status transaction_description time_created time_updated time_deleted
4 1 250.0000 USD Refunded Test payment 2026-03-29 13:30:12 2026-04-01 15:15:12 NULL
5 1 250.0000 USD Refunded API test transaction 2026-04-10 18:08:56 2026-04-10 22:25:53 NULL
6 1 100.0000 USD Completed Auth test run 2026-04-17 21:47:51 2026-04-17 21:50:09 NULL

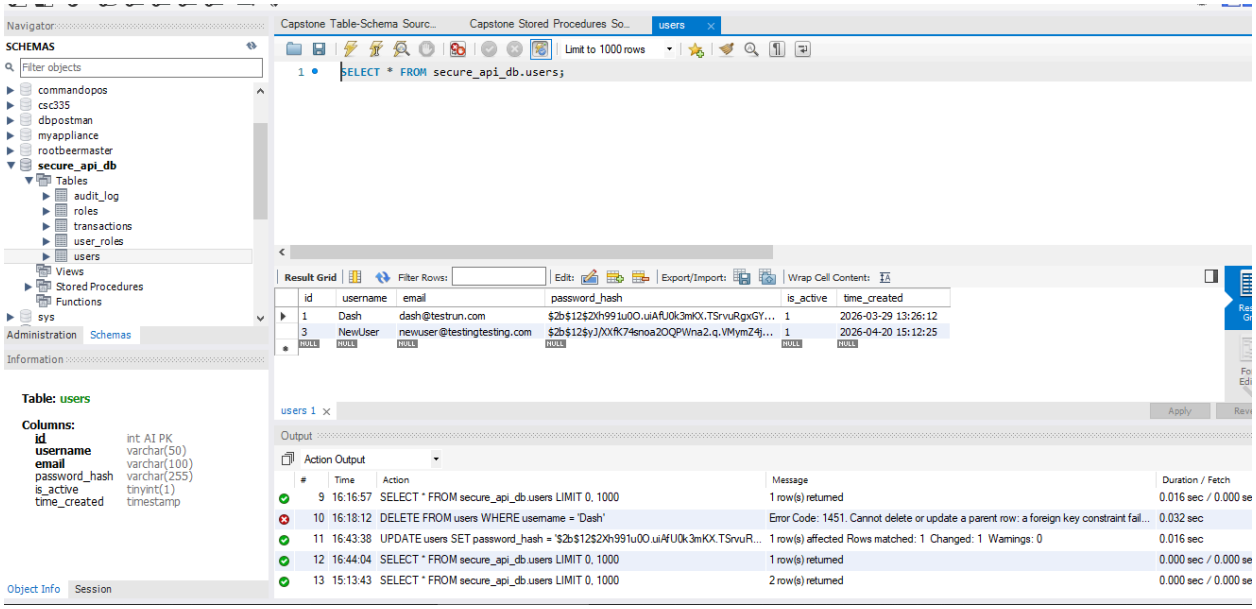

Navigator
SCHEMAS
Filter objects
commandopos
csc335
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
Functions
sys
Administration
Schemas
Information
Table: users
Columns:
id int AI PK
username varchar(50)
email varchar(100)
password_hash varchar(255)
is_active tinyint(1)
time_created timestamp
Object Info
Session
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
users
Limit to 1000 rows
1 SELECT * FROM secure_api_db.users;
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Cell Content:
id username email password_hash is_active time_created
1 Dash dash@testrun.com $2b$12$2Xh991u0O.uiAfU0k3mKX.TSrvuRgxGY... 1 2026-03-29 13:26:12
users 1
Output
Action Output
Time Action Message
8 16:15:49 use secure_api_db 0 row(s) affected
9 16:16:57 SELECT * FROM secure_api_db.users LIMIT 0, 1000 1 row(s) returned
10 16:18:12 DELETE FROM users WHERE username = 'Dash' Error Code: 1451. Cannot delete or update a parent row: a for
11 16:43:38 UPDATE users SET password_hash = '$2b$12$2Xh991u0O.uiAfU0k3mKX.TSrvuR... 1 row(s) affected Rows matched: 1 Changed: 1 Warnings: 0
12 16:44:04 SELECT * FROM secure_api_db.users LIMIT 0, 1000 1 row(s) returned

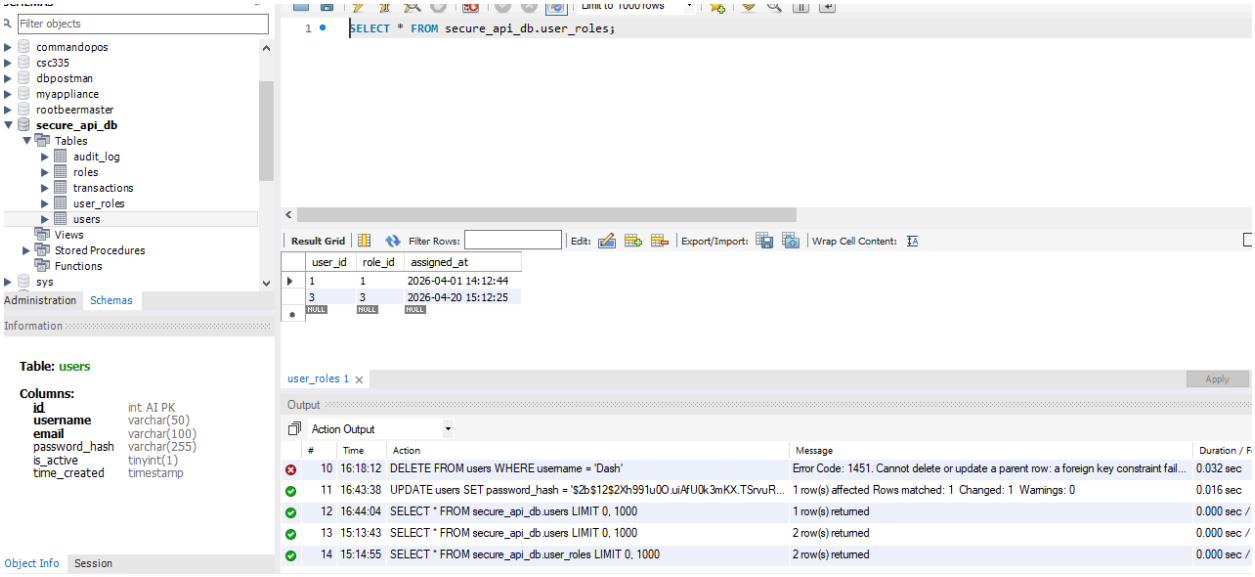
The following images demonstrate a newly registered user creating a transaction, but not having the authorization to change the status,and proof of the successful processes in MySQL:






Responses
Curl
curl -X 'POST' \
'http://127.0.0.1:8000/register' \
-H 'accept: application/json' \
-H 'Content-Type: application/json' \
-d '{
"username": "NewUser",
"email": "newuser@testingtesting.com",
"password": "NewUserPassword"
}'
Request URL
http://127.0.0.1:8000/register
Server response
Code
Details
200
Response body
{
"Message": "User has been registered successfully"
}
Download
Response headers
content-length: 51
content-type: application/json
date: Mon,20 Apr 2026 22:12:24 GMT
server: uvicorn
Responses


Navigator
SCHEMAS
Filter objects
commandopos
csc335
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
Functions
sys
Administration
Schemas
Information
Table: users
Columns:
id int AI PK
username varchar(50)
email varchar(100)
password_hash varchar(255)
is_active tinyint(1)
time_created timestamp
Object Info
Session
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
users
Limit to 1000 rows
1 SELECT * FROM secure_api_db.users;
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Cell Content:
id username email password_hash is_active time_created
1 Dash dash@testrun.com $2b$12$2Xh991u0O.uiAfU0k3mKX.TSrvuRgxGY... 1 2026-03-29 13:26:12
3 NewUser newuser@testingtesting.com $2b$12$yJ/XXfK74snoa2OQPWna2.q.VMymZ4j... 1 2026-04-20 15:12:25
users 1
Apply
Output
Action Output
Time Action Message Duration / Fetch
9 16:16:57 SELECT * FROM secure_api_db.users LIMIT 0, 1000 1 row(s) returned 0.016 sec / 0.000 se
10 16:18:12 DELETE FROM users WHERE username = 'Dash' Error Code: 1451. Cannot delete or update a parent row: a foreign key constraint fail... 0.032 sec
11 16:43:38 UPDATE users SET password_hash = '$2b$12$2Xh991u0O.uiAfU0k3mKX.TSrvuR... 1 row(s) affected Rows matched: 1 Changed: 1 Warnings: 0 0.016 sec
12 16:44:04 SELECT * FROM secure_api_db.users LIMIT 0, 1000 1 row(s) returned 0.000 sec / 0.000 se
13 15:13:43 SELECT * FROM secure_api_db.users LIMIT 0, 1000 2 row(s) returned 0.000 sec / 0.000 se



Curl

```
curl -X 'POST' \
  'http://127.0.0.1:8000/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "NewUser",
  "password": "NewUserPassword"
}'
```

Request URL

```
http://127.0.0.1:8000/login
```

Server response

Code	Details
200	Response body

```
{
  "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjozLCJ1c2VybmFtZSI6Ik5ld1VzZXIiLCJleHAiOjE3NzY3MjUyMjN9.xPfmr38pDQX1v2ptB0R1JlfqtlBIKr8JjKDhO99GlQU"
}
```

Download

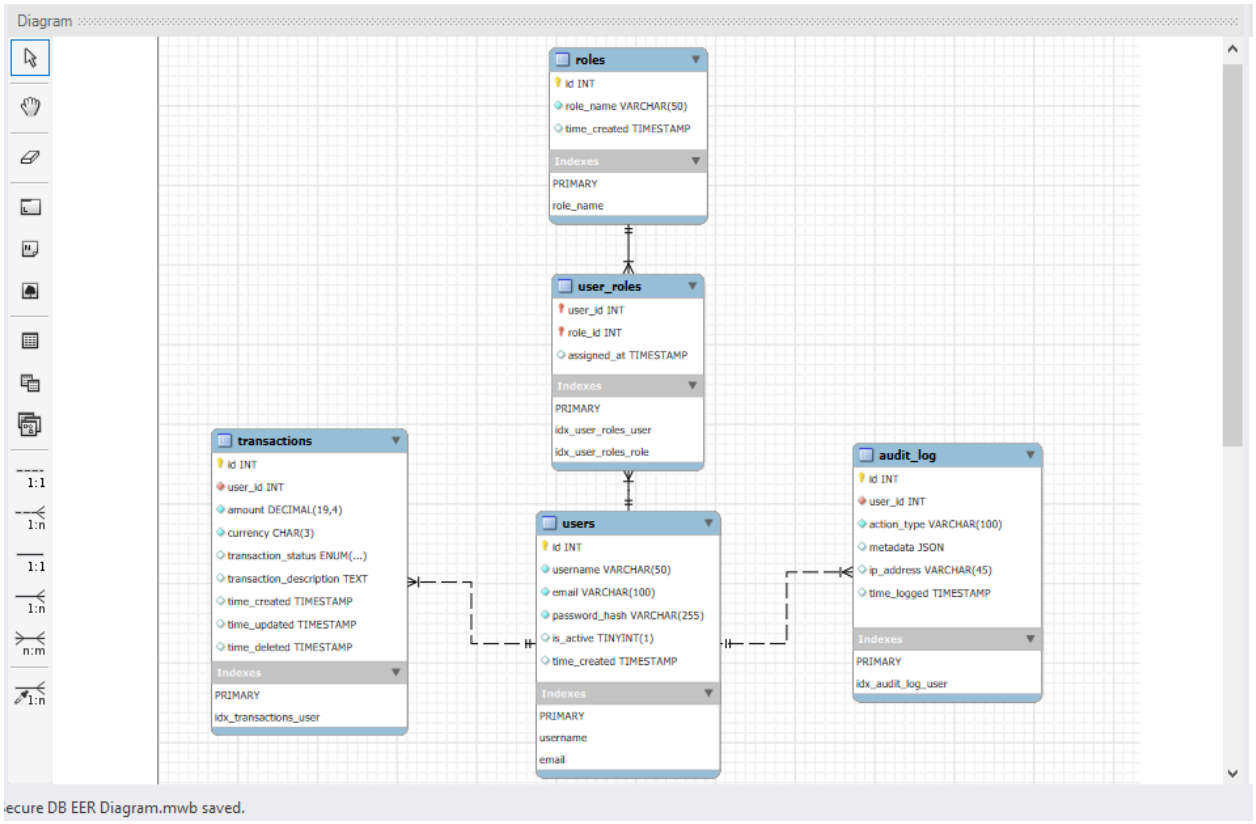
Response headers

```
content-length: 168
content-type: application/json
date: Mon,20 Apr 2026 22:17:42 GMT
server: uvicorn
```

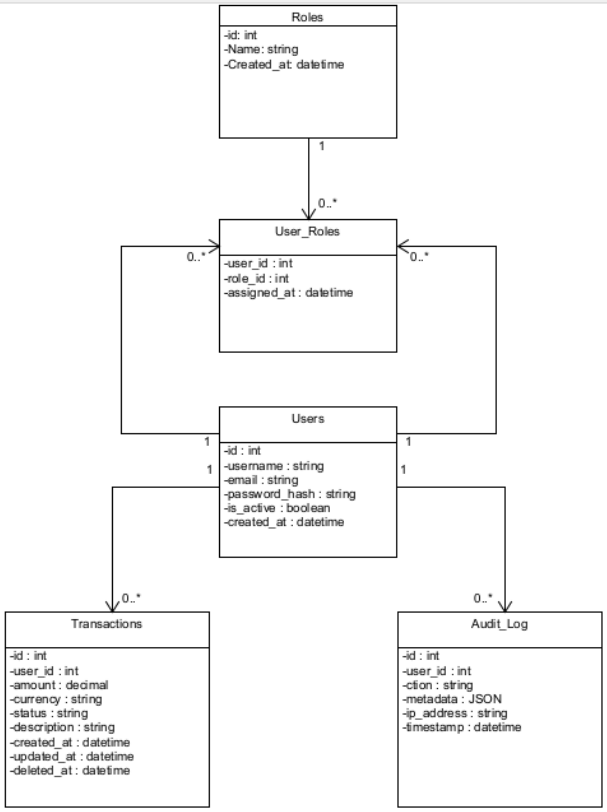
Responses

Code	Description	Links

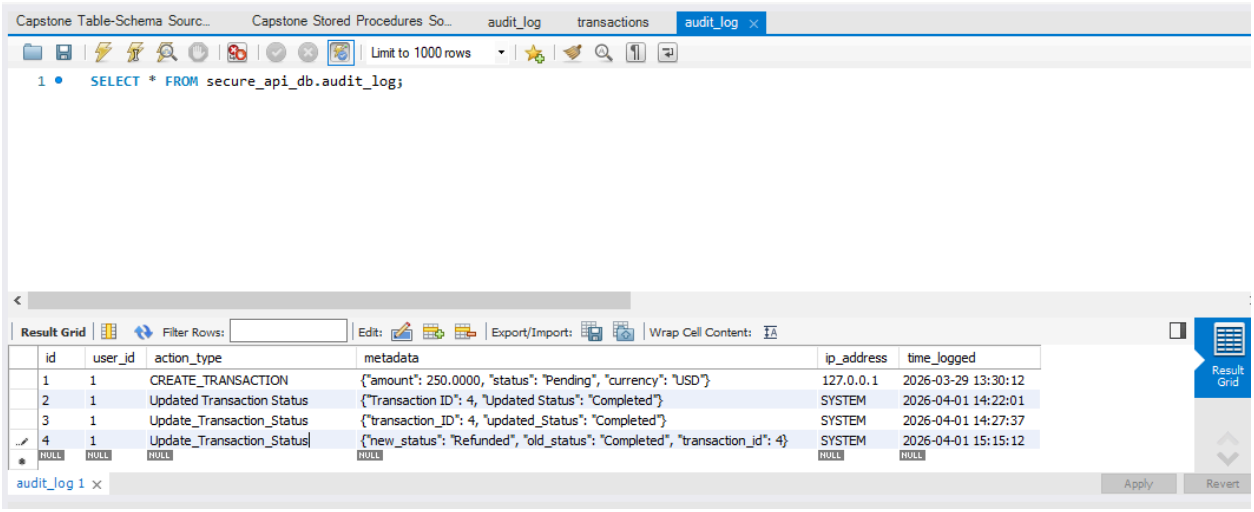
The following image is of the EER reverse engineered DB/Schema diagram, along with the original planned database design:

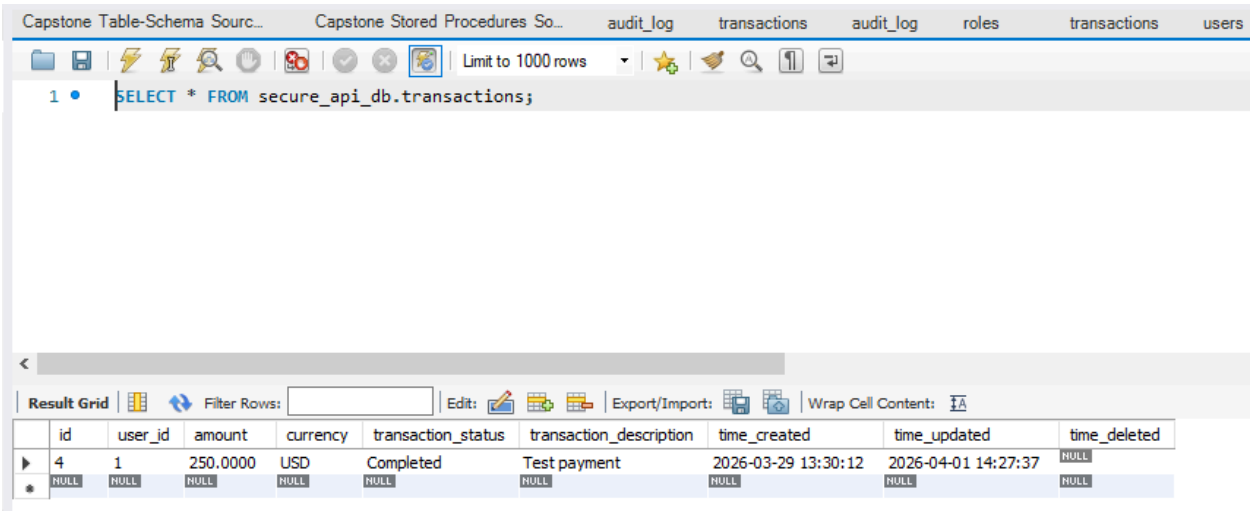


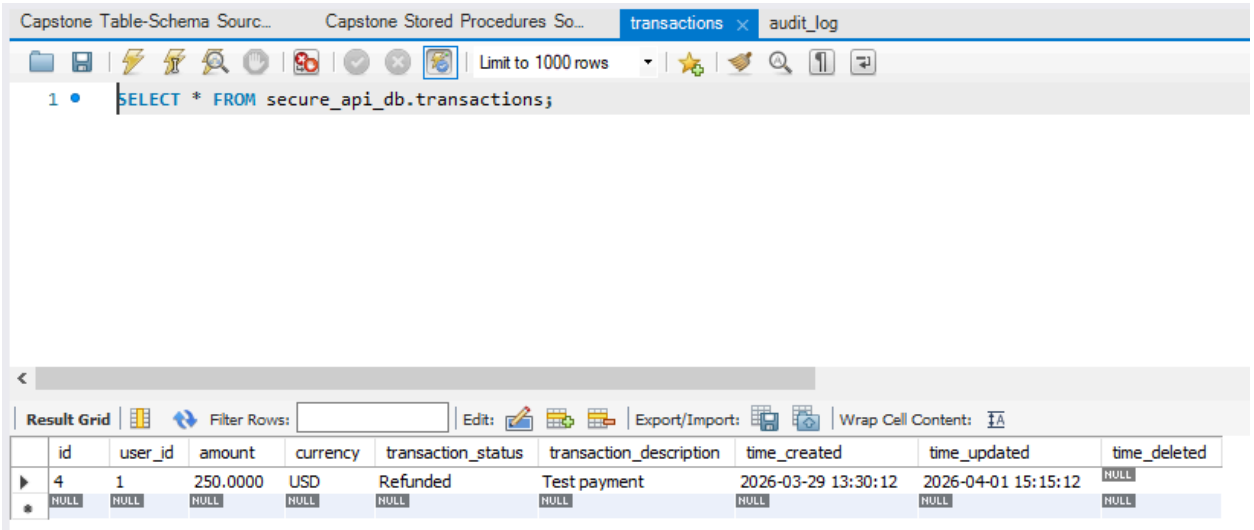
Capstone-Database Class Diagram ×

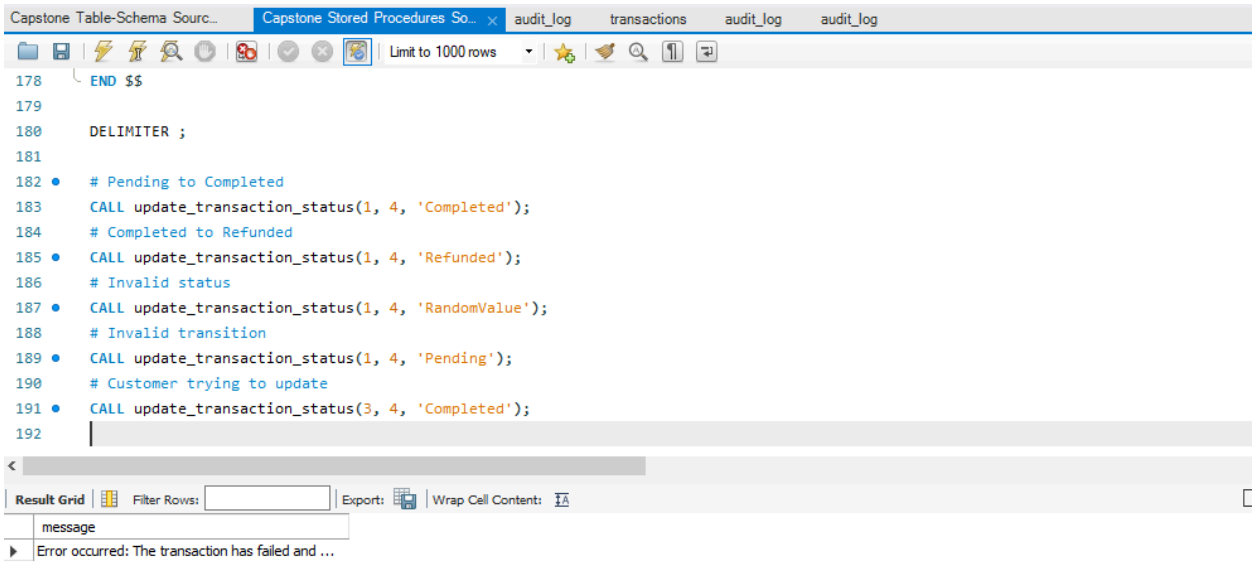


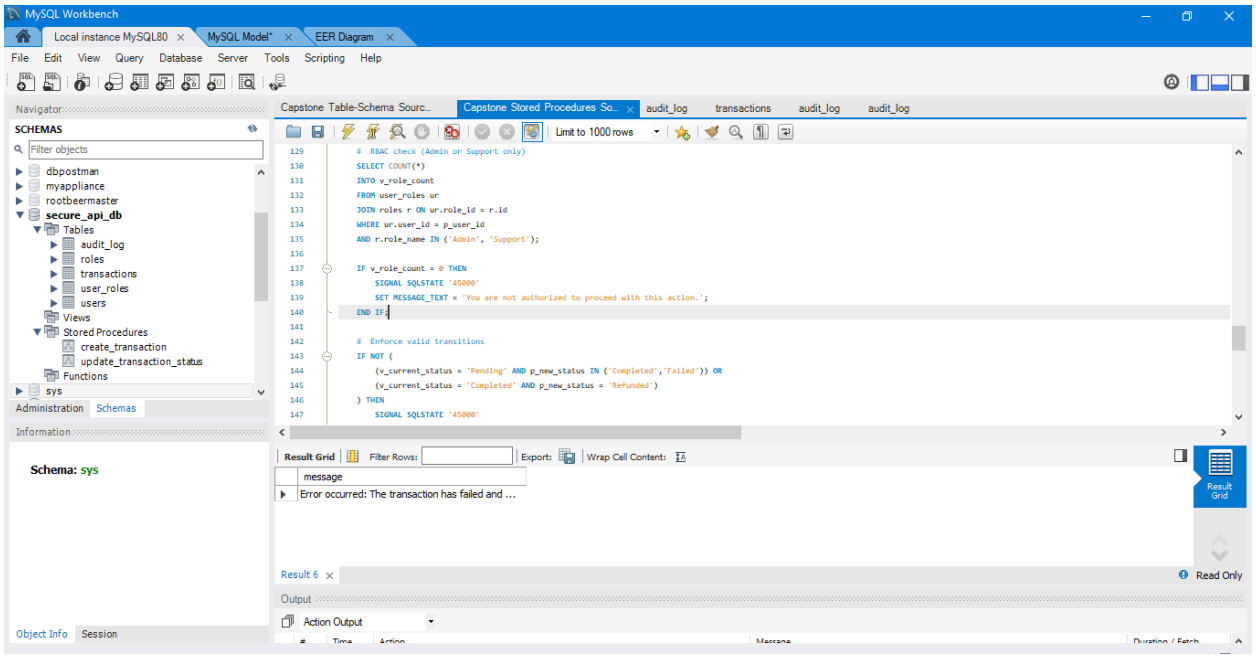
The following images show the queries and internal DB messages of the stored procedures:



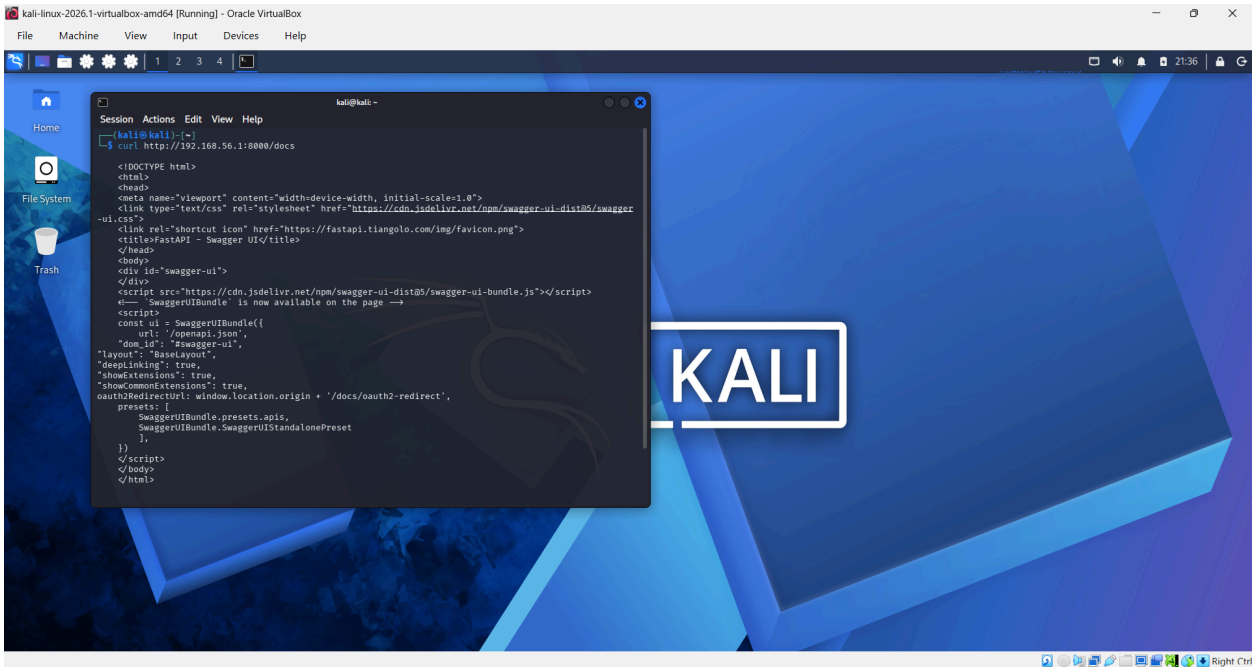


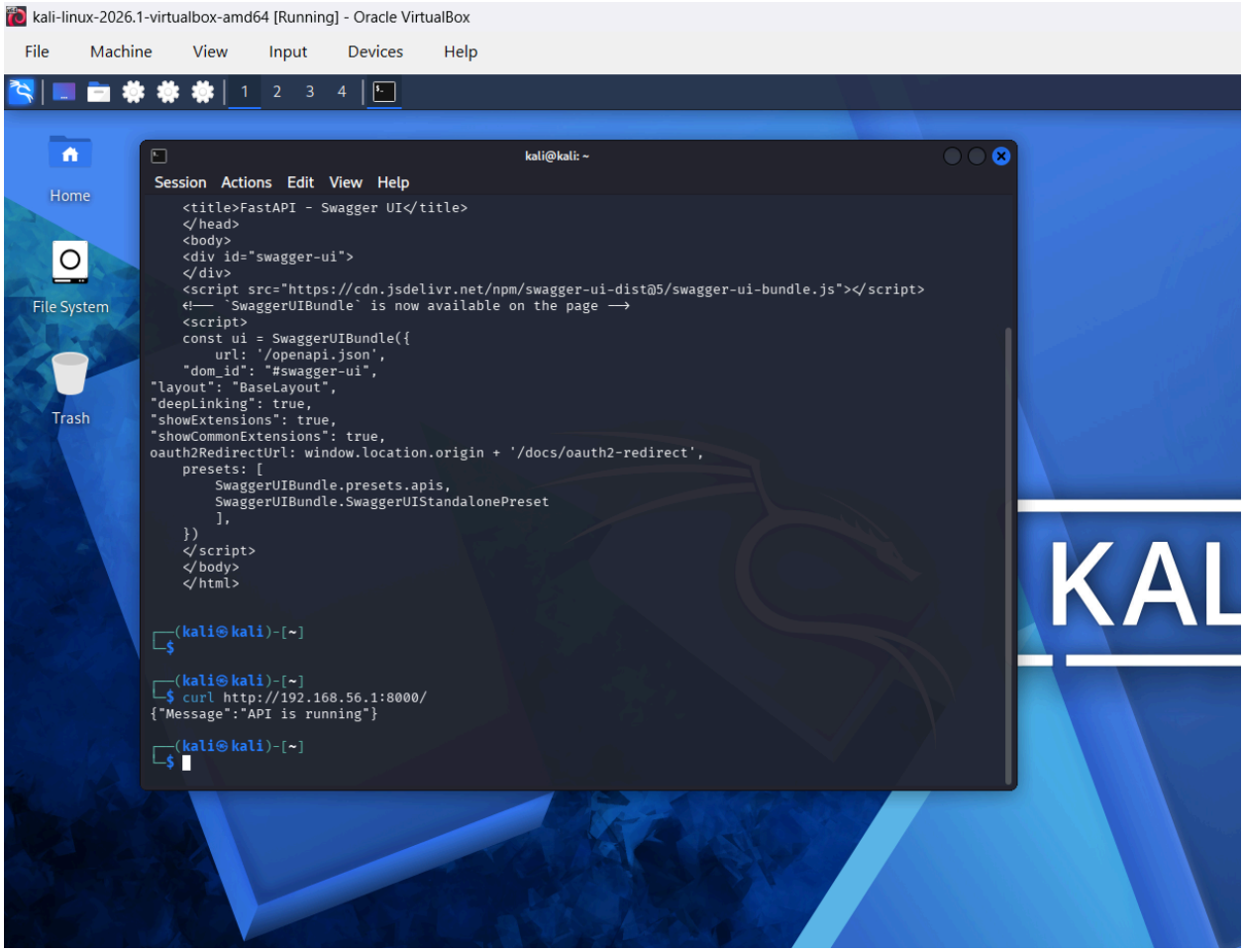


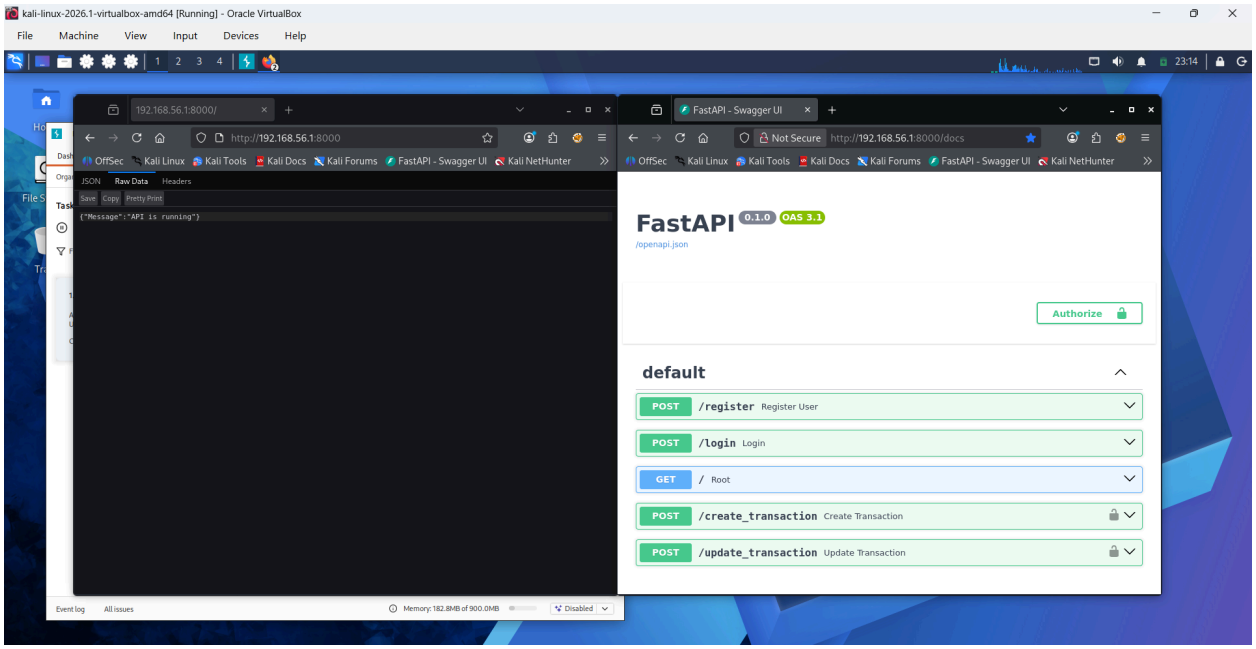

Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
audit_log
transactions
audit_log
audit_log
Limit to 1000 rows
178 END $$
179
180 DELIMITER ;
181
182 # Pending to Completed
183 CALL update_transaction_status(1, 4, 'Completed');
184 # Completed to Refunded
185 CALL update_transaction_status(1, 4, 'Refunded');
186 # Invalid status
187 CALL update_transaction_status(1, 4, 'RandomValue');
188 # Invalid transition
189 CALL update_transaction_status(1, 4, 'Pending');
190 # Customer trying to update
191 CALL update_transaction_status(3, 4, 'Completed');
192
Result Grid
Filter Rows:
Export:
Wrap Cell Content:
message
Error occurred: The transaction has failed and ...


MySQL Workbench
Local instance MySQL80
MySQL Model*
EER Diagram
File Edit View Query Database Server Tools Scripting Help
Navigator
SCHEMAS
Filter objects
dbpostman
myappliance
rootbeermaster
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
create_transaction
update_transaction_status
Functions
sys
Administration
Schemas
Information
Schema: sys
Object Info
Session
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
audit_log
transactions
audit_log
audit_log
Limit to 1000 rows
129 # RBAC check (Admin or Support only)
130 SELECT COUNT(*)
131 INTO v_role_count
132 FROM user_roles ur
133 JOIN roles r ON ur.role_id = r.id
134 WHERE ur.user_id = p_user_id
135 AND r.role_name IN ('Admin', 'Support');
136
137 IF v_role_count = 0 THEN
138 SIGNAL SQLSTATE '45000'
139 SET MESSAGE_TEXT = 'You are not authorized to proceed with this action.';
140 END IF;
141
142 # Enforce valid transitions
143 IF NOT (
144 (v_current_status = 'Pending' AND p_new_status IN ('Completed','Failed')) OR
145 (v_current_status = 'Completed' AND p_new_status = 'Refunded')
146) THEN
147 SIGNAL SQLSTATE '45000'
Result Grid
Filter Rows:
Export:
Wrap Cell Content:
message
Error occurred: The transaction has failed and ...
Result Grid
Result 6
Read Only
Output
Action Output

The following source code demonstrates the Kali Linux to FastAPI connection:

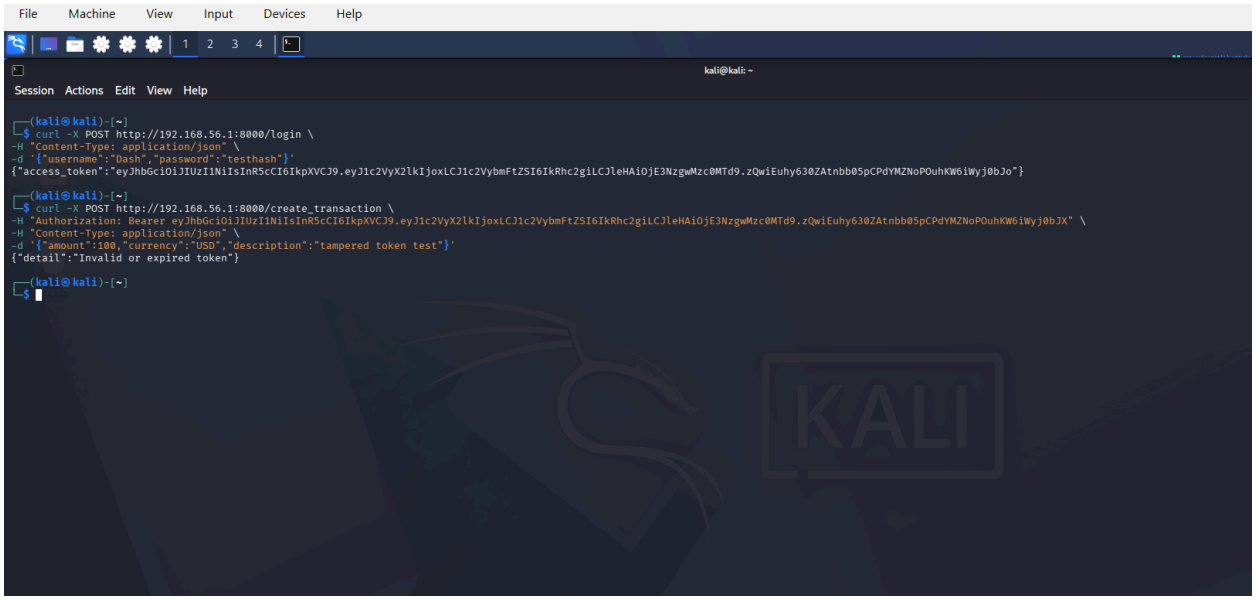


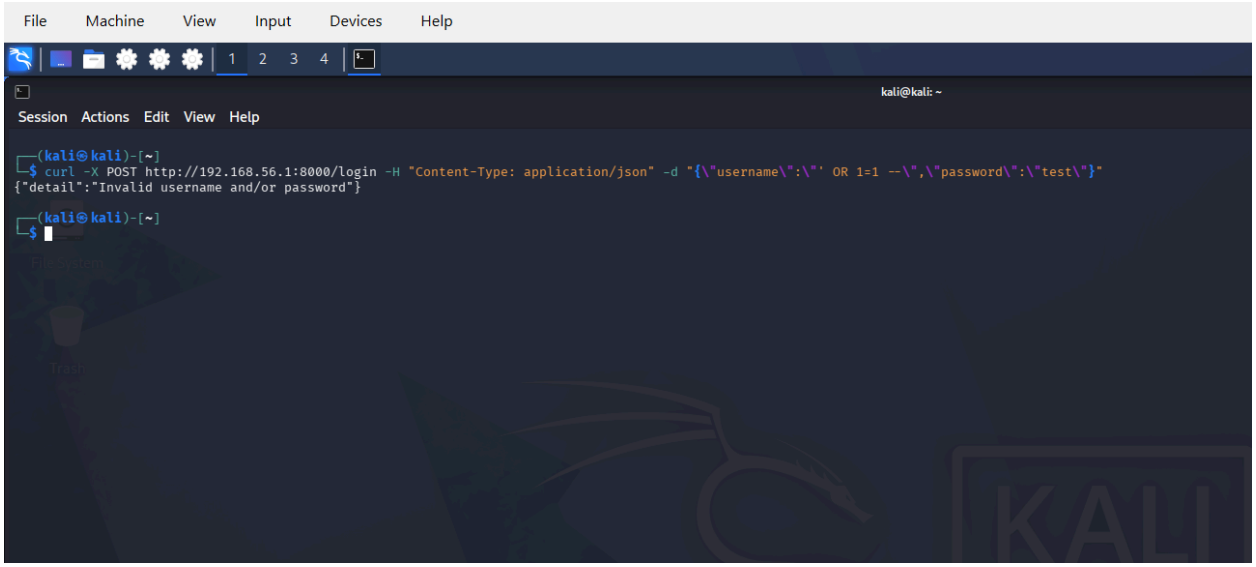


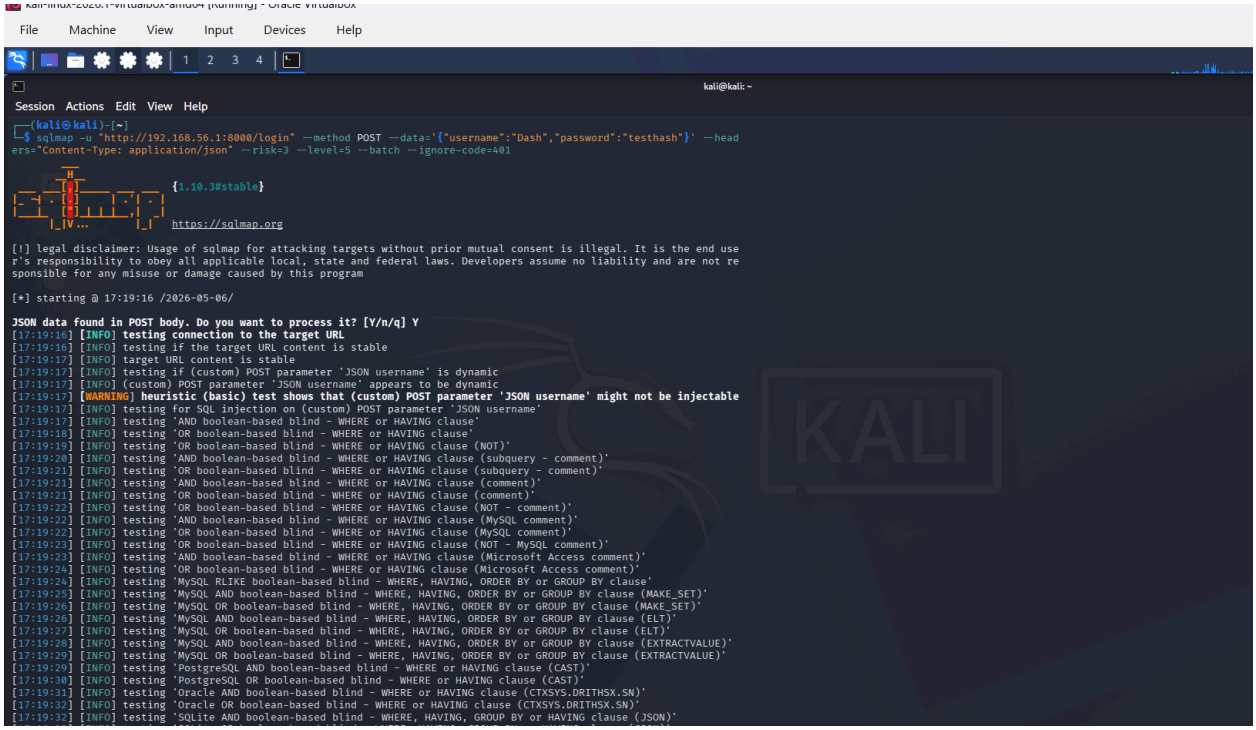


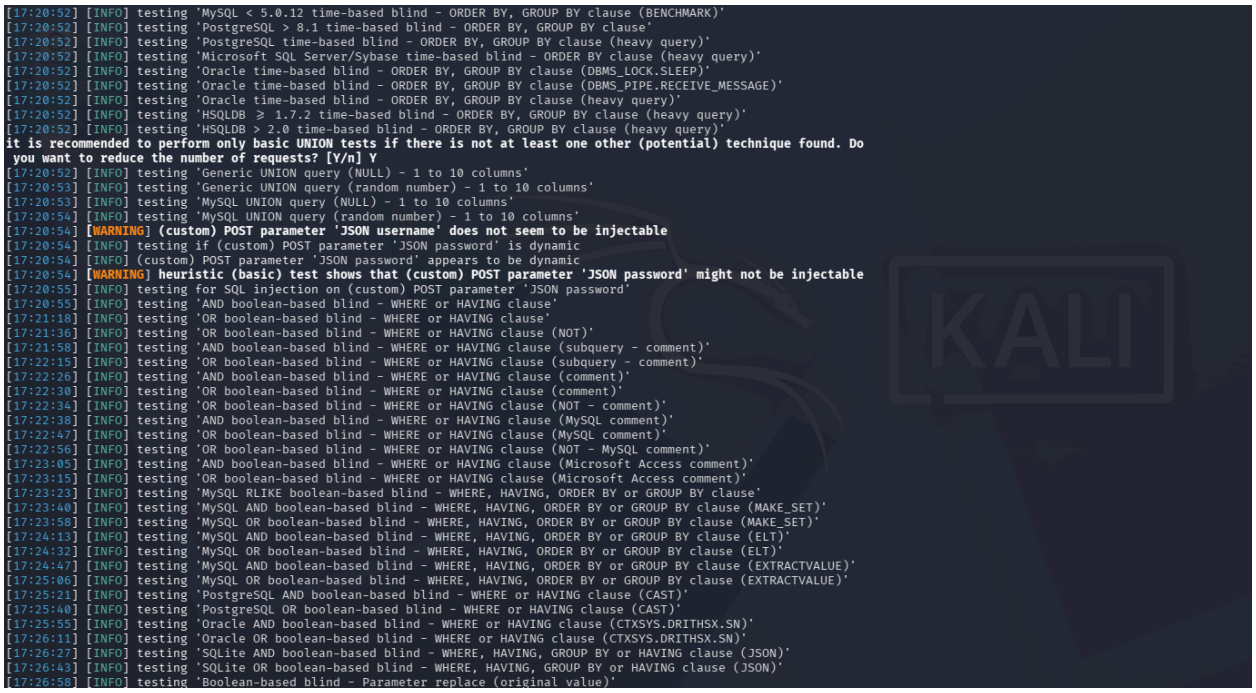
The following images demonstrate the curl and SQLMap tests from the Kali Linux VM:




File Machine View Input Devices Help
1 2 3 4
kali@kali: ~
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ curl -X POST http://192.168.56.1:8000/login \
-H "Content-Type: application/json" \
-d '{"username":"Dash","password":"testhash"}'
{"access_token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLCJleHAiOjE3NzgwMzc0MTd9.zQwiEuhy630ZAtnbb05pCPdYMZNoPOuhKW6iWyj0bJo"}
┌──(kali㉿kali)-[~]
└─$ curl -X POST http://192.168.56.1:8000/create_transaction \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLCJleHAiOjE3NzgwMzc0MTd9.zQwiEuhy630ZAtnbb05pCPdYMZNoPOuhKW6iWyj0bJX" \
-H "Content-Type: application/json" \
-d '{"amount":100,"currency":"USD","description":"tampered token test"}'
{"detail":"Invalid or expired token"}
┌──(kali㉿kali)-[~]
└─$

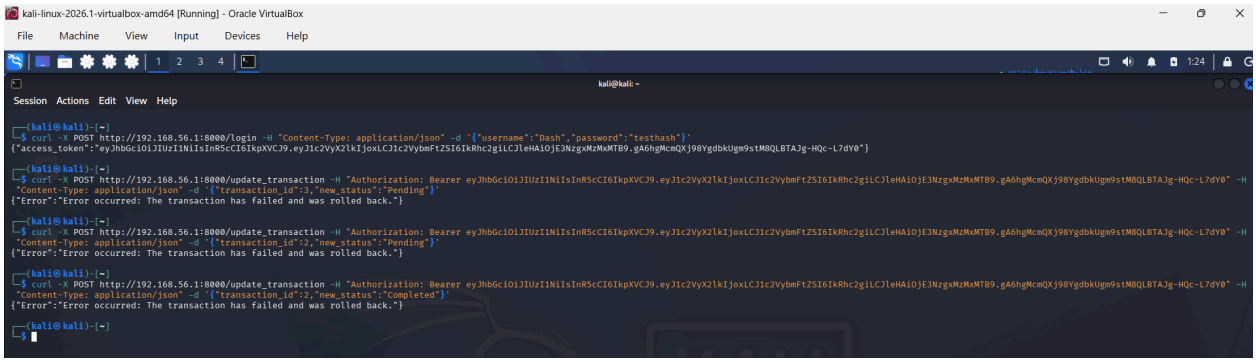

File Machine View Input Devices Help
1 2 3 4
kali@kali: ~
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ curl -X POST http://192.168.56.1:8000/login -H "Content-Type: application/json" -d "{\"username\":\"' OR 1=1 --\",\"password\":\"test\"}"
{"detail":"Invalid username and/or password"}
┌──(kali㉿kali)-[~]
└─$

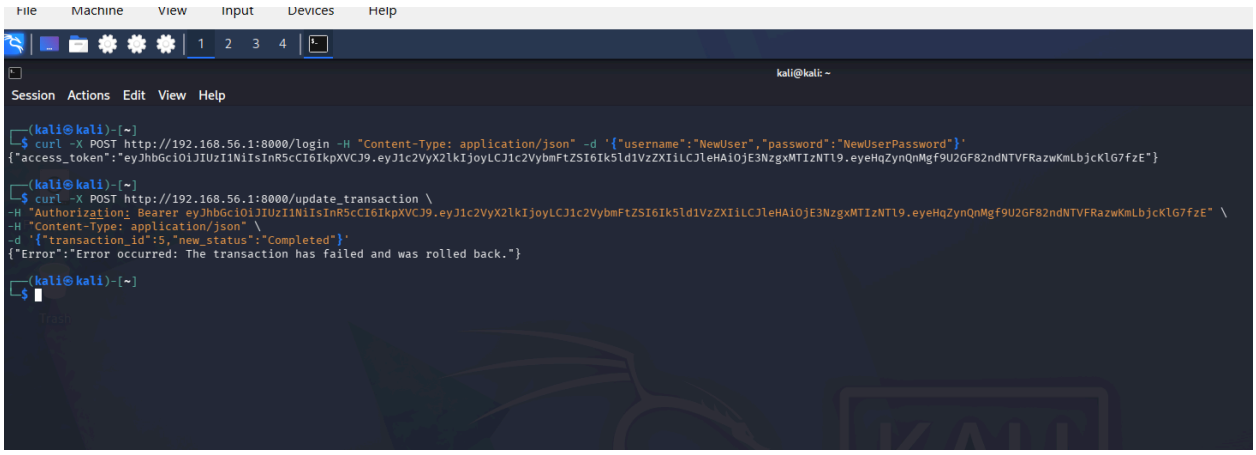

File Machine View Input Devices Help
kali@kali: ~
Session Actions Edit View Help
(kali㉿kali)-[~]
$ sqlmap -u "http://192.168.56.1:8000/login" --method POST --data='{"username":"Dash","password":"testhash"}' --headers="Content-Type: application/json" --risk=3 --level=5 --batch --ignore-code=401
{1.10.3#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 17:19:16 /2026-05-06/
JSON data found in POST body. Do you want to process it? [Y/n/q] Y
[17:19:16] [INFO] testing connection to the target URL
[17:19:16] [INFO] testing if the target URL content is stable
[17:19:17] [INFO] target URL content is stable
[17:19:17] [INFO] testing if (custom) POST parameter 'JSON username' is dynamic
[17:19:17] [INFO] (custom) POST parameter 'JSON username' appears to be dynamic
[17:19:17] [WARNING] heuristic (basic) test shows that (custom) POST parameter 'JSON username' might not be injectable
[17:19:17] [INFO] testing for SQL injection on (custom) POST parameter 'JSON username'
[17:19:17] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[17:19:18] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'
[17:19:19] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT)'
[17:19:20] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[17:19:21] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[17:19:21] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'
[17:19:21] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'
[17:19:22] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'
[17:19:22] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[17:19:22] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[17:19:23] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[17:19:23] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[17:19:24] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[17:19:24] [INFO] testing 'MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause'
[17:19:25] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[17:19:26] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[17:19:26] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[17:19:27] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[17:19:28] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[17:19:29] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[17:19:29] [INFO] testing 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)'
[17:19:30] [INFO] testing 'PostgreSQL OR boolean-based blind - WHERE or HAVING clause (CAST)'
[17:19:31] [INFO] testing 'Oracle AND boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)'
[17:19:32] [INFO] testing 'Oracle OR boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)'
[17:19:32] [INFO] testing 'SQLite AND boolean-based blind - WHERE, HAVING, GROUP BY or HAVING clause (JSON)'


[17:20:52] [INFO] testing 'MySQL < 5.0.12 time-based blind - ORDER BY, GROUP BY clause (BENCHMARK)'
[17:20:52] [INFO] testing 'PostgreSQL > 8.1 time-based blind - ORDER BY, GROUP BY clause'
[17:20:52] [INFO] testing 'PostgreSQL time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:20:52] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind - ORDER BY clause (heavy query)'
[17:20:52] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_LOCK.SLEEP)'
[17:20:52] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_PIPE.RECEIVE_MESSAGE)'
[17:20:52] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:20:52] [INFO] testing 'HSQLDB ≥ 1.7.2 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:20:52] [INFO] testing 'HSQLDB > 2.0 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[17:20:52] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[17:20:53] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'
[17:20:53] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[17:20:54] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[17:20:54] [WARNING] (custom) POST parameter 'JSON username' does not seem to be injectable
[17:20:54] [INFO] testing if (custom) POST parameter 'JSON password' is dynamic
[17:20:54] [INFO] (custom) POST parameter 'JSON password' appears to be dynamic
[17:20:54] [WARNING] heuristic (basic) test shows that (custom) POST parameter 'JSON password' might not be injectable
[17:20:55] [INFO] testing for SQL injection on (custom) POST parameter 'JSON password'
[17:20:55] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[17:21:18] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'
[17:21:36] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT)'
[17:21:58] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[17:22:15] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[17:22:26] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'
[17:22:30] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'
[17:22:34] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'
[17:22:38] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[17:22:47] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[17:22:56] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[17:23:05] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[17:23:15] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[17:23:23] [INFO] testing 'MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause'
[17:23:40] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[17:23:58] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[17:24:13] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[17:24:32] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[17:24:47] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[17:25:06] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[17:25:21] [INFO] testing 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)'
[17:25:40] [INFO] testing 'PostgreSQL OR boolean-based blind - WHERE or HAVING clause (CAST)'
[17:25:55] [INFO] testing 'Oracle AND boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)'
[17:26:11] [INFO] testing 'Oracle OR boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)'
[17:26:27] [INFO] testing 'SQLite AND boolean-based blind - WHERE, HAVING, GROUP BY or HAVING clause (JSON)'
[17:26:43] [INFO] testing 'SQLite OR boolean-based blind - WHERE, HAVING, GROUP BY or HAVING clause (JSON)'
[17:26:58] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'

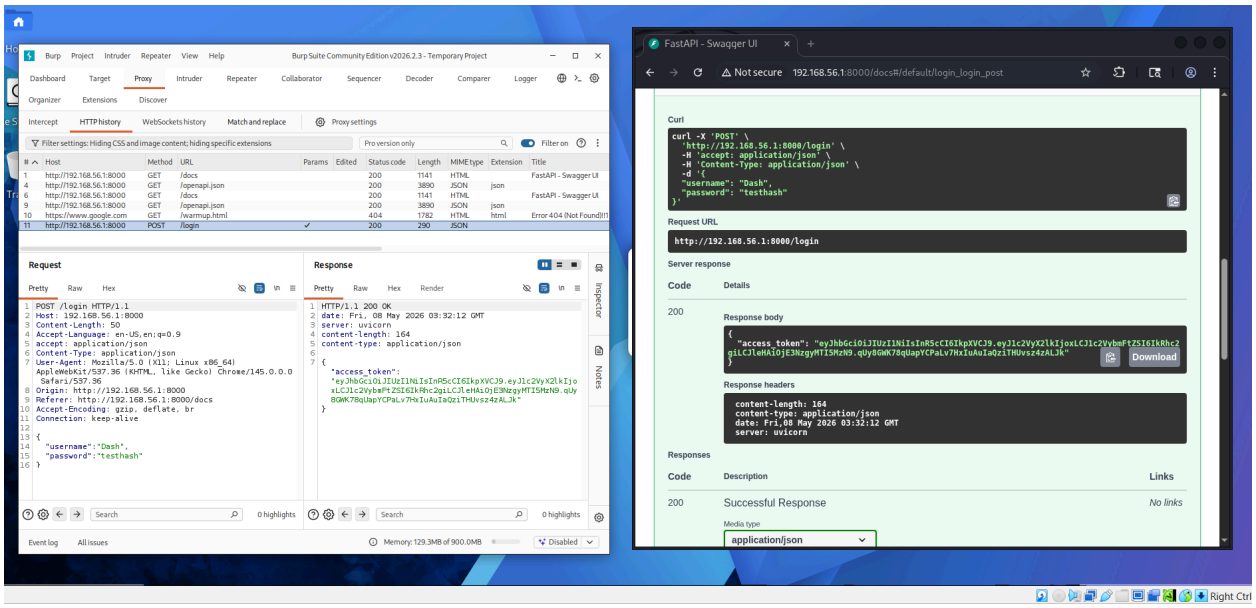
```
[17:54:42] [INFO] testing 'MySQL < 5.0.12 time-based blind - ORDER BY, GROUP BY clause (BENCHMARK)'
[17:54:42] [INFO] testing 'PostgreSQL > 8.1 time-based blind - ORDER BY, GROUP BY clause'
[17:54:43] [INFO] testing 'PostgreSQL time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:54:43] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind - ORDER BY clause (heavy query)'
[17:54:44] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_LOCK.SLEEP)'
[17:54:44] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_PIPE.RECEIVE_MESSAGE)'
[17:54:45] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:54:45] [INFO] testing 'HSQLDB ≥ 1.7.2 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:54:46] [INFO] testing 'HSQLDB > 2.0 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[17:54:46] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[17:54:55] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'
[17:55:04] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[17:55:13] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[17:55:23] [WARNING] (custom) POST parameter 'JSON password' does not seem to be injectable
other non-custom parameters found. Do you want to process them too? [Y/n/q] Y
[17:55:23] [INFO] testing if parameter 'User-Agent' is dynamic
[17:55:23] [INFO] parameter 'User-Agent' appears to be dynamic
[17:55:23] [WARNING] heuristic (basic) test shows that parameter 'User-Agent' might not be injectable
[17:55:23] [INFO] testing for SQL injection on parameter 'User-Agent'
[17:55:23] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[17:55:49] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'
[17:56:09] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT)'
[17:56:34] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[17:56:52] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[17:57:05] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'
[17:57:10] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'
[17:57:14] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'
[17:57:18] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[17:57:29] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[17:57:38] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[17:57:49] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[17:58:00] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[17:58:10] [INFO] testing 'MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause'
[17:58:28] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[17:58:48] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[17:59:05] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[17:59:25] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[17:59:42] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[18:00:02] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[18:00:19] [INFO] testing 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)'
[18:00:39] [INFO] testing 'PostgreSQL OR boolean-based blind - WHERE or HAVING clause (CAST)'
[18:00:56] [INFO] testing 'Oracle AND boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)'
[18:01:15] [INFO] testing 'Oracle OR boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)'
```

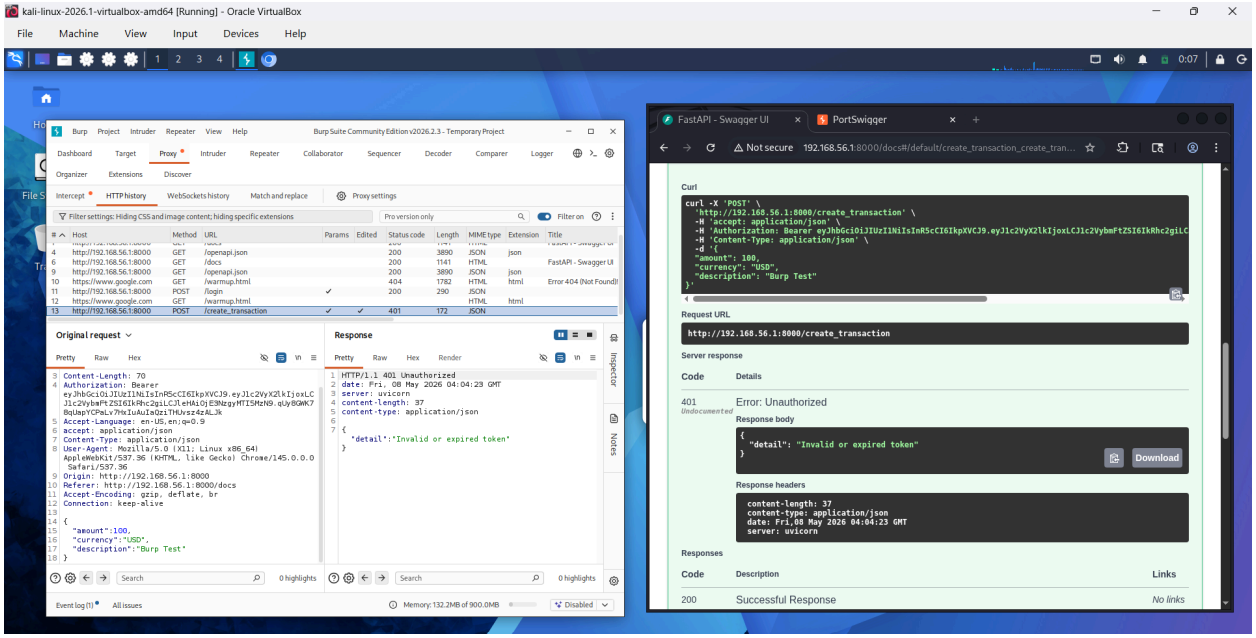
```
[18:31:44] [INFO] testing 'Oracle time-based blind - Parameter replace (DBMS_LOCK.SLEEP)'
[18:31:44] [INFO] testing 'Oracle time-based blind - Parameter replace (DBMS_PIPE.RECEIVE_MESSAGE)'
[18:31:44] [INFO] testing 'Oracle time-based blind - Parameter replace (heavy queries)'
[18:31:45] [INFO] testing 'SQLite > 2.0 time-based blind - Parameter replace (heavy query)'
[18:31:45] [INFO] testing 'Firebird time-based blind - Parameter replace (heavy query)'
[18:31:45] [INFO] testing 'SAP MaxDB time-based blind - Parameter replace (heavy query)'
[18:31:45] [INFO] testing 'IBM DB2 time-based blind - Parameter replace (heavy query)'
[18:31:46] [INFO] testing 'HSQLDB ≥ 1.7.2 time-based blind - Parameter replace (heavy query)'
[18:31:46] [INFO] testing 'HSQLDB > 2.0 time-based blind - Parameter replace (heavy query)'
[18:31:46] [INFO] testing 'Informix time-based blind - Parameter replace (heavy query)'
[18:31:46] [INFO] testing 'MySQL ≥ 5.0.12 time-based blind - ORDER BY, GROUP BY clause'
[18:31:47] [INFO] testing 'MySQL < 5.0.12 time-based blind - ORDER BY, GROUP BY clause (BENCHMARK)'
[18:31:47] [INFO] testing 'PostgreSQL > 8.1 time-based blind - ORDER BY, GROUP BY clause'
[18:31:48] [INFO] testing 'PostgreSQL time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[18:31:48] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind - ORDER BY clause (heavy query)'
[18:31:49] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_LOCK.SLEEP)'
[18:31:49] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_PIPE.RECEIVE_MESSAGE)'
[18:31:50] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[18:31:50] [INFO] testing 'HSQLDB ≥ 1.7.2 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[18:31:51] [INFO] testing 'HSQLDB > 2.0 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[18:31:51] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[18:32:01] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'
[18:32:10] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[18:32:19] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[18:32:28] [WARNING] parameter 'User-Agent' does not seem to be injectable
[18:32:28] [INFO] testing if parameter 'Referer' is dynamic
[18:32:28] [INFO] parameter 'Referer' appears to be dynamic
[18:32:28] [WARNING] heuristic (basic) test shows that parameter 'Referer' might not be injectable
[18:32:29] [INFO] testing for SQL injection on parameter 'Referer'
[18:32:29] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[18:32:54] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'
[18:33:14] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT)'
[18:33:39] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[18:33:57] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[18:34:11] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'
[18:34:16] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'
[18:34:20] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'
[18:34:25] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[18:34:36] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[18:34:46] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[18:34:57] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[18:35:08] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (Microsoft Access comment)'
[18:35:19] [INFO] testing 'MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause'
[18:35:39] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[18:35:41] [WARNING] user aborted during detection phase
```

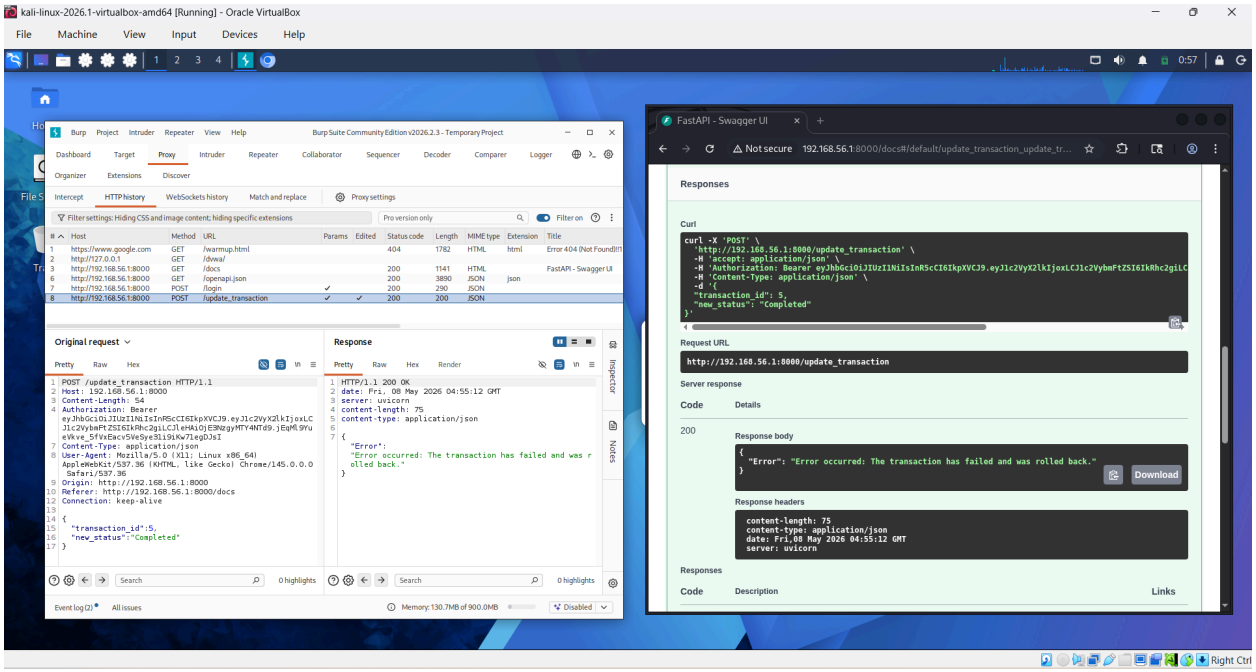




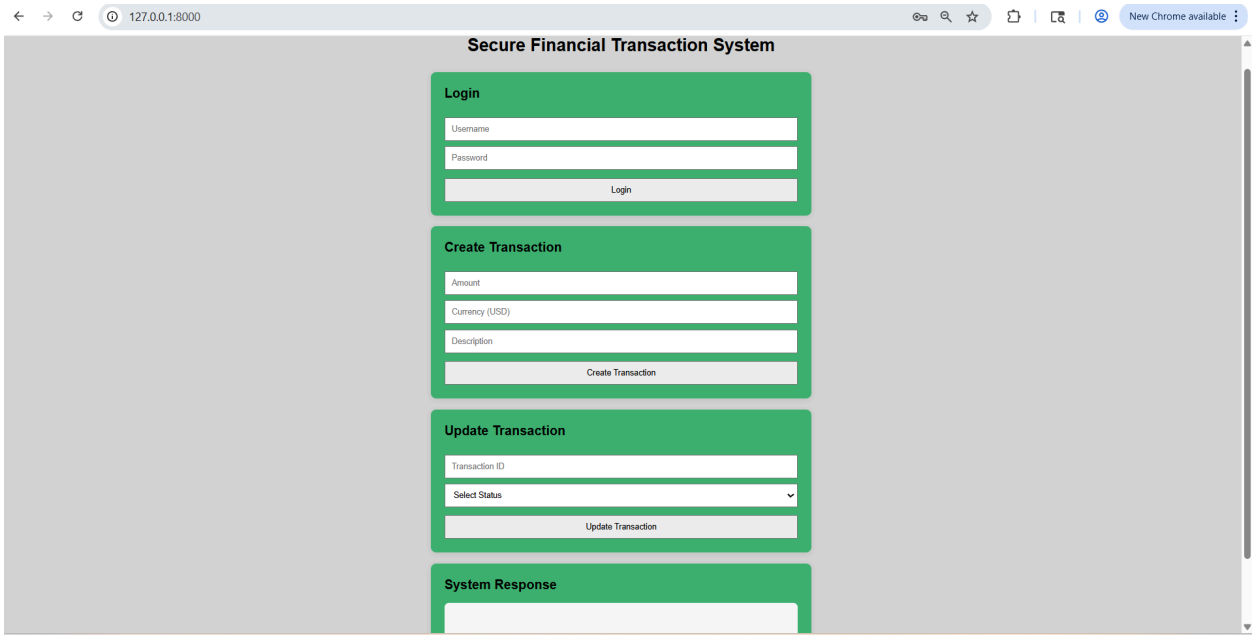
The following images are of the security tests and information gathering done with BurpSuite:

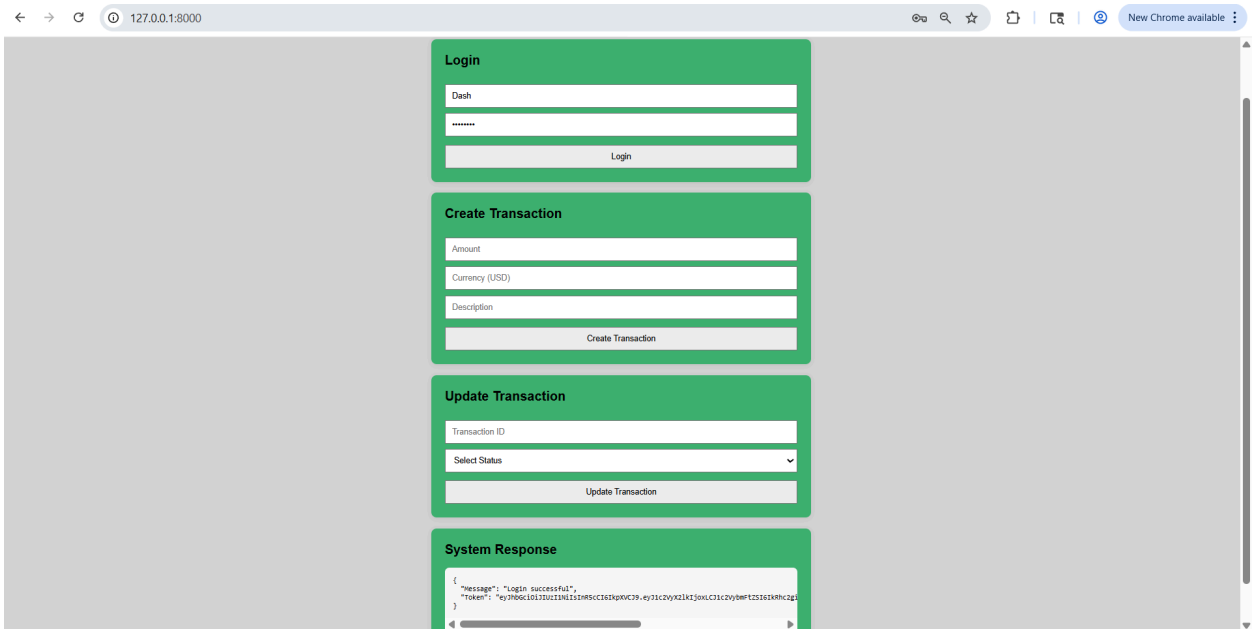


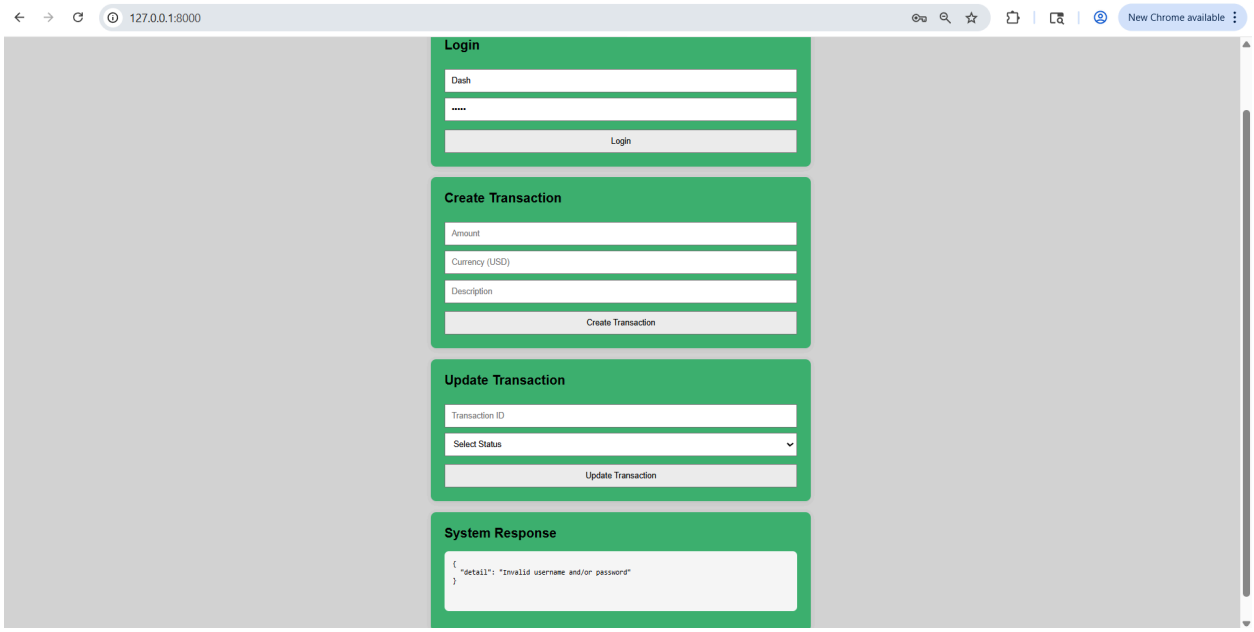

kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Burp Suite Community Edition v2026.2.3 - Temporary Project
Original request
Response
FastAPI - Swagger UI
PortSwigger
Not secure 192.168.56.1:8000/docs#/default/create_transaction_create_tran...
Curl
curl -X 'POST' \
'http://192.168.56.1:8000/create_transaction' \
-H 'accept: application/json' \
-H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLC
-H 'Content-Type: application/json' \
-d '{
"amount": 100,
"currency": "USD",
"description": "Burp Test"
}'
Request URL
http://192.168.56.1:8000/create_transaction
Server response
Code
Details
401
Undocumented
Error: Unauthorized
Response body
{
"detail": "Invalid or expired token"
}
Download
Response headers
content-length: 37
content-type: application/json
date: Fri,08 May 2026 04:04:23 GMT
server: uvicorn
Responses
Code
Description
Links
200
Successful Response
No links


kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Burp Suite Community Edition v2026.2.3 - Temporary Project
Original request
Response
FastAPI - Swagger UI
Not secure 192.168.56.1:8000/docs#/default/update_transaction_update_tr...
Responses
Curl
curl -X 'POST' \
'http://192.168.56.1:8000/update_transaction' \
-H 'accept: application/json' \
-H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkRhc2giLC
-H 'Content-Type: application/json' \
-d '{
"transaction_id": 5,
"new_status": "Completed"
}'
Request URL
http://192.168.56.1:8000/update_transaction
Server response
Code
Details
200
Response body
{
"Error": "Error occurred: The transaction has failed and was rolled back."
}
Download
Response headers
content-length: 75
content-type: application/json
date: Fri,08 May 2026 04:55:12 GMT
server: uvicorn
Responses
Code
Description
Links
Right Ctrl

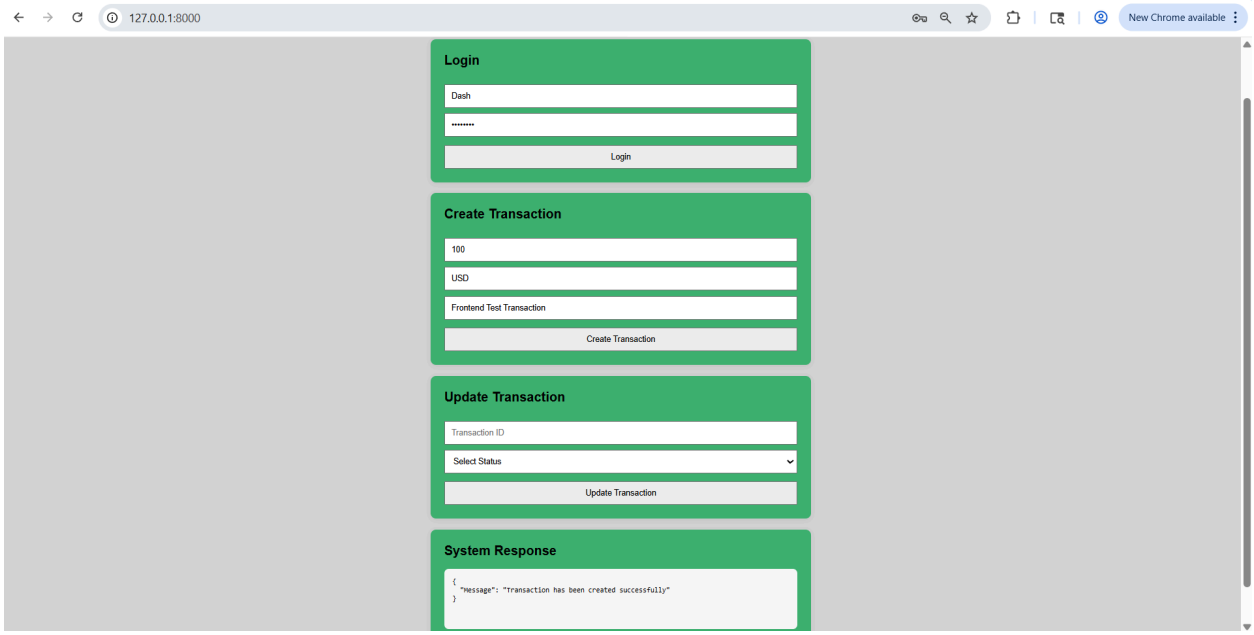
The following images are of the API frontend, successful login attempt, and a wrong password login attempt:

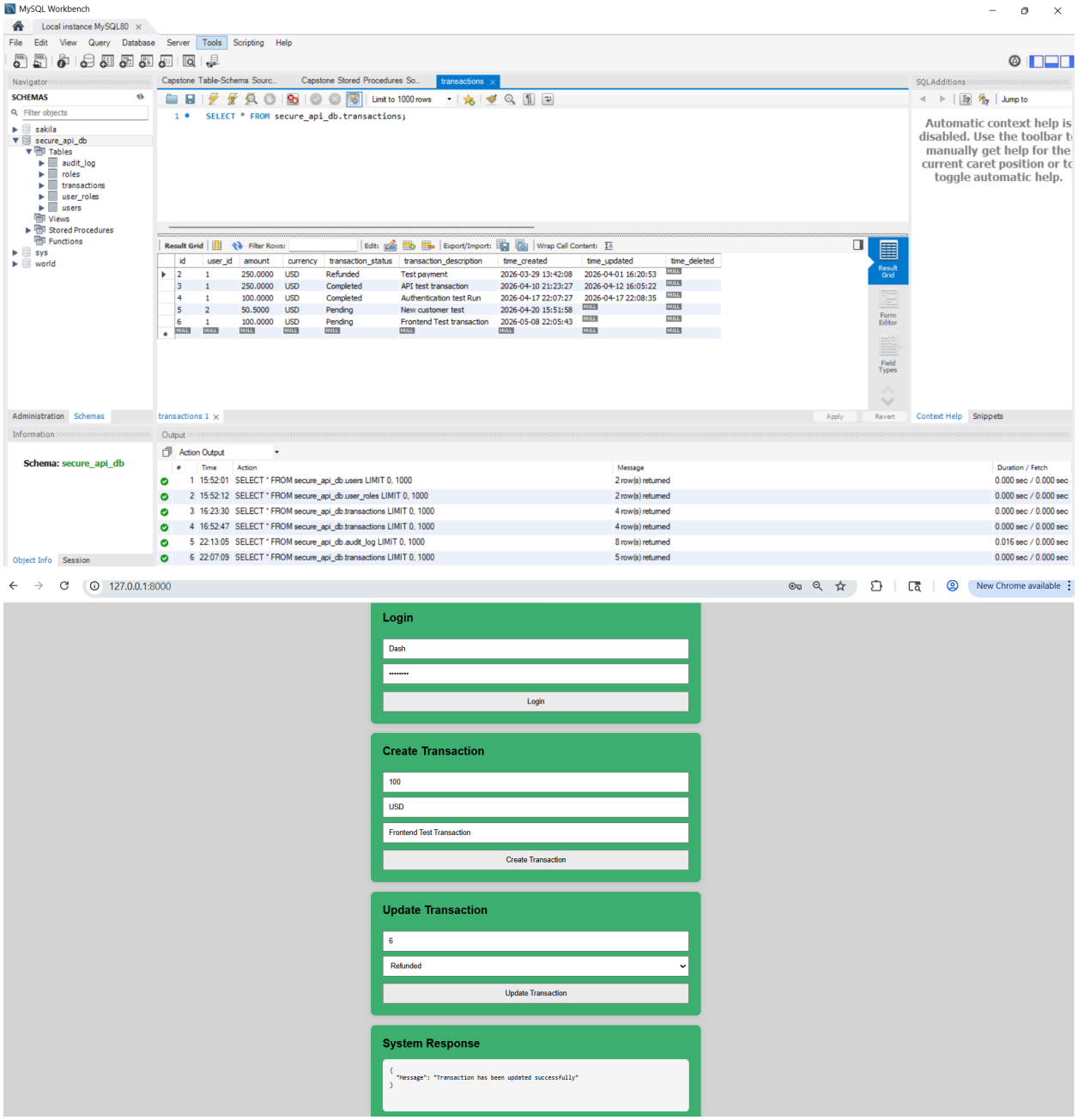


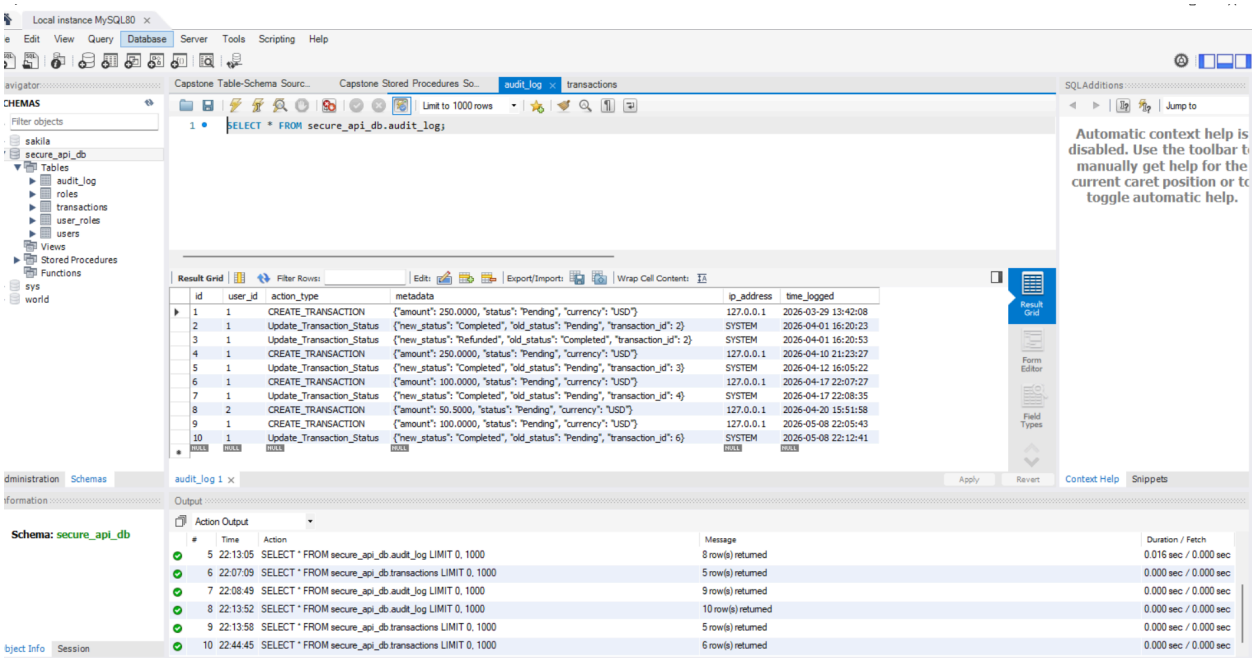




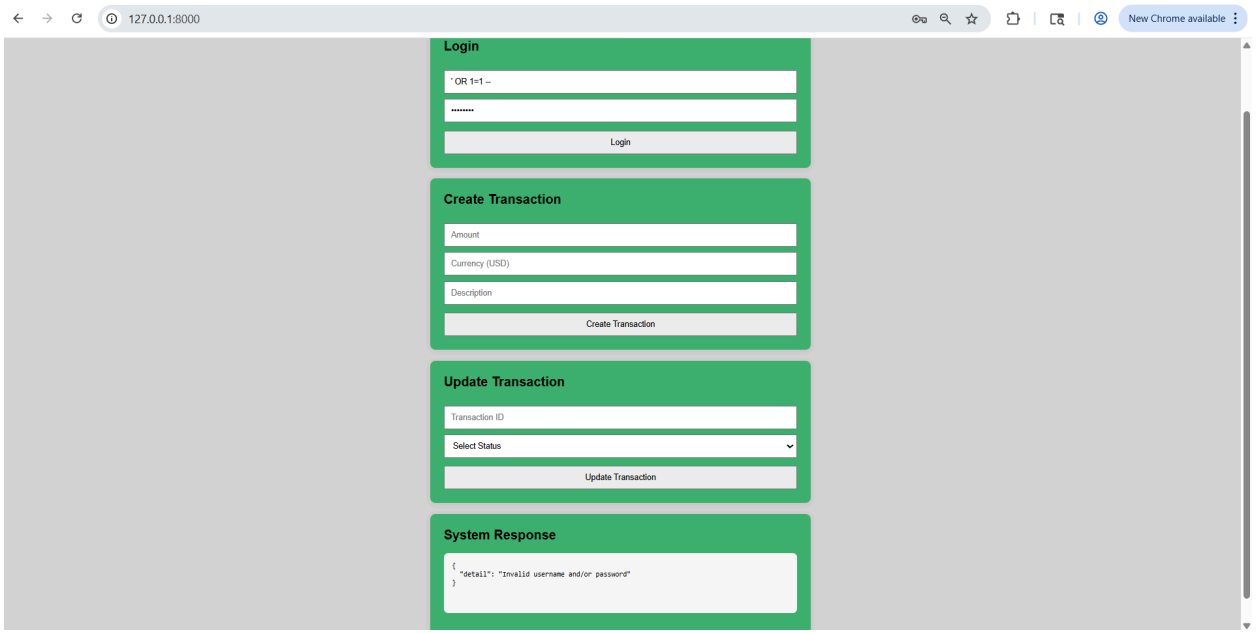
The following images are of a successfully created transaction through the frontend, with MySQL proof, and a transaction updated successfully, with MySQL proof:

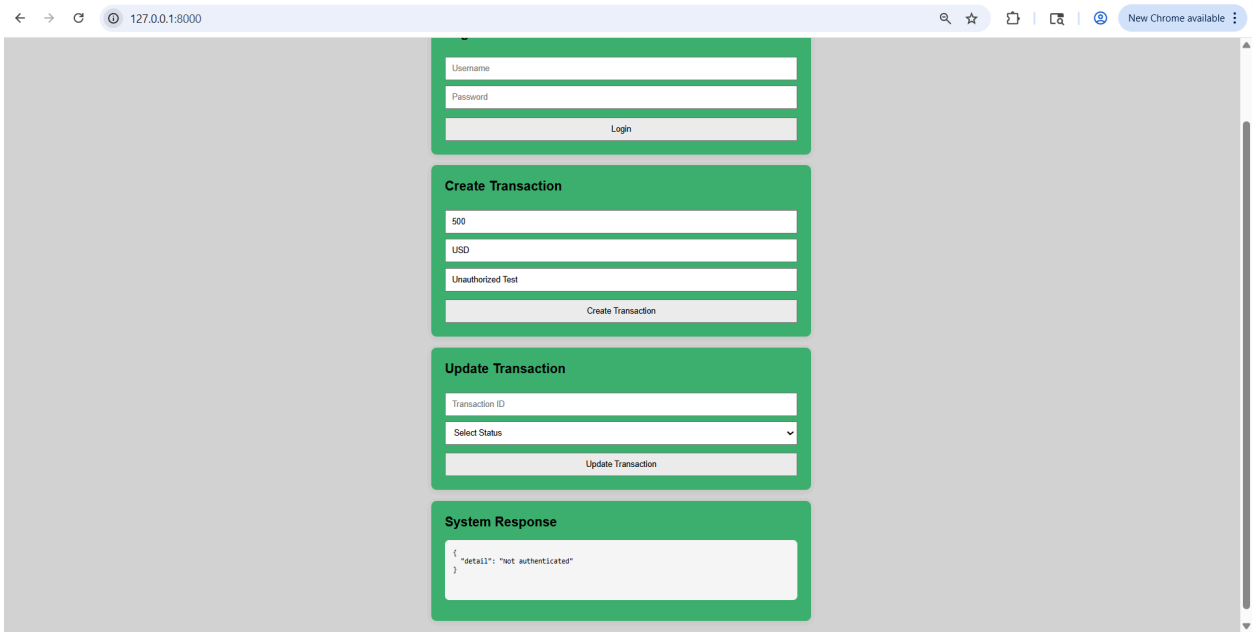


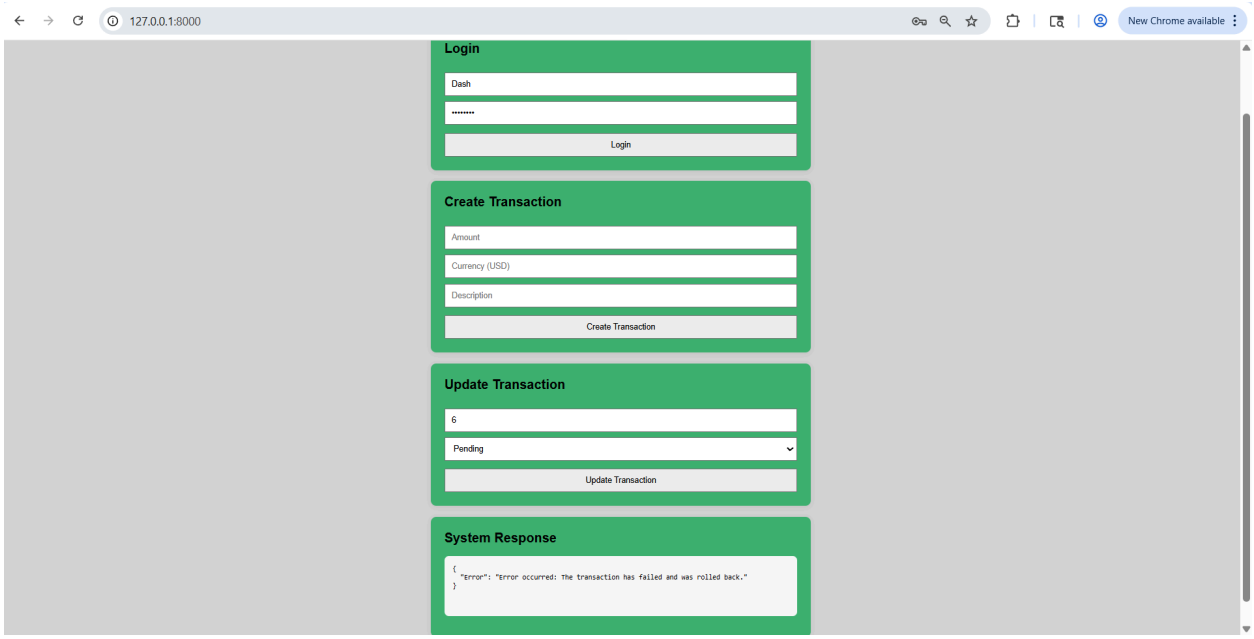

MySQL Workbench
Local instance MySQL80
File Edit View Query Database Server Tools Scripting Help
Navigator
SCHEMAS
Filter objects
sakila
secure_api_db
Tables
audit_log
roles
transactions
user_roles
users
Views
Stored Procedures
Functions
sys
world
Capstone Table-Schema Sourc...
Capstone Stored Procedures So...
transactions
Limit to 1000 rows
1 SELECT * FROM secure_api_db.transactions;
SQLAdditions
Jump to
Automatic context help is disabled. Use the toolbar t manually get help for the current caret position or to toggle automatic help.
Result Grid
Filter Rows:
Edit:
Export/Import:
Wrap Call Content:
id user_id amount currency transaction_status transaction_description time_created time_updated time_deleted
2 1 250.0000 USD Refunded Test payment 2026-03-29 13:42:08 2026-04-01 16:20:53 NULL
3 1 250.0000 USD Completed API test transaction 2026-04-10 21:23:27 2026-04-12 16:05:22 NULL
4 1 100.0000 USD Completed Authentication test Run 2026-04-17 22:07:27 2026-04-17 22:08:35 NULL
5 2 50.5000 USD Pending New customer test 2026-04-20 15:51:58 NULL NULL
6 1 100.0000 USD Pending Frontend Test transaction 2026-05-08 22:05:43 NULL NULL
Result Grid
Form Editor
Field Types
Administration Schemas
transactions 1
Apply
Revert
Context Help Snippets
Information
Schema: secure_api_db
Object Info Session
Output
Action Output
Time Action Message Duration / Fetch
1 15:52:01 SELECT * FROM secure_api_db.users LIMIT 0, 1000 2 row(s) returned 0.000 sec / 0.000 sec
2 15:52:12 SELECT * FROM secure_api_db.user_roles LIMIT 0, 1000 2 row(s) returned 0.000 sec / 0.000 sec
3 16:23:30 SELECT * FROM secure_api_db.transactions LIMIT 0, 1000 4 row(s) returned 0.000 sec / 0.000 sec
4 16:52:47 SELECT * FROM secure_api_db.transactions LIMIT 0, 1000 4 row(s) returned 0.000 sec / 0.000 sec
5 22:13:05 SELECT * FROM secure_api_db.audit_log LIMIT 0, 1000 8 row(s) returned 0.016 sec / 0.000 sec
6 22:07:09 SELECT * FROM secure_api_db.transactions LIMIT 0, 1000 5 row(s) returned 0.000 sec / 0.000 sec
127.0.0.1:8000
New Chrome available
Login
Dash
Login
Create Transaction
100
USD
Frontend Test Transaction
Create Transaction
Update Transaction
6
Refunded
Update Transaction
System Response
{
"Message": "Transaction has been updated successfully"
}



The following images demonstrate an SQL injection attempt through the frontend, an unauthorized attempt to create a transaction, and an invalid status transition:




127.0.0.1:8000
New Chrome available
Username
Password
Login
Create Transaction
500
USD
Unauthorized Test
Create Transaction
Update Transaction
Transaction ID
Select Status
Update Transaction
System Response
{
"detail": "Not authenticated"
}


127.0.0.1:8000
New Chrome available
Login
Dash
Login
Create Transaction
Amount
Currency (USD)
Description
Create Transaction
Update Transaction
6
Pending
Update Transaction
System Response
{
"error": "Error occurred: The transaction has failed and was rolled back."
}